# GRC LAB 1 REPORT

Practical Vulnerability Assessment for GRC Professionals

| | |
|---|---|
| **Analyst** | Oluwatosin Olajubu |
| **Role in the lab** | Internal auditor / GRC analyst performing a technical assessment of a test system |
| **Target** | Metasploitable test server 192.168.164.129 (development environment) |
| **Attacker / scanner** | Kali Linux 192.168.164.128 |
| **Assessment date** | 22 October 2026 |
| **Report date** | 23 October 2026 |
| **Tools** | ping, Nmap 7.95, xsltproc, Nikto 2.5.0, Nuclei v3.11.1 |
| **Result at a glance** | 38 findings: 6 Critical, 14 High, 10 Medium, 8 Low; 30 open TCP ports; Nuclei 59 results |
| **Companion files** | GRC_Lab1_Vulnerability_Assessment_Report.docx (formal report); GRC_Lab1_Risk_Assessment_Register.xlsx (register, heat map, mappings) |

> This report documents an authorised exercise against an intentionally vulnerable training machine. No exploitation was performed. Findings and ratings are preliminary, are not CVSS scores and must not be applied to production systems.

# Contents

**1. Introduction and Objectives** 4
1.1 Purpose 4
1.2 Objectives 4
1.3 Approach and structure 4
1.4 Deliverables checklist 4
**2. Lab Environment and Setup** 5
**3. Phase 1: Discovery and Enumeration** 8
3.1 Step 1: Network discovery 8
3.2 Step 2: Port and service enumeration with Nmap 8
**4. Phase 2: Vulnerability Identification** 16
4.1 Step 3: Analysing the Nmap output 16
4.2 Step 4: Web application assessment with Nikto 16
4.3 Step 5: Focused vulnerability scanning with Nuclei 18
**5. Phase 3: Analysis and Reporting** 23
5.1 Step 6: Triage and risk assessment 23
5.2 Step 7: Executive summary 27
**6. Remediation Plan** 29
**7. Lessons Learned and Limitations** 29
7.1 Lessons learned 29
7.2 Limitations 29
**8. Conclusion** 30
**9. Evidence Inventory** 30
**Appendix A. Nuclei Results (all)** 31
**Appendix B. Nikto Results (27 items)** 34
**Appendix C. Nmap Grepable Output** 36
**Appendix D. Command Reference** 36

## List of tables

Table 1: Lab steps mapped to report sections 4
Table 2: Lab deliverables and where they are covered 4
Table 3: Lab environment 5
Table 4: Nmap options used 8
Table 5: All 30 open TCP ports with initial security concern and related findings 14
Table 6: Service versions identified 16
Table 7: Interesting script outputs 16
Table 8: Nikto findings and why they matter 17
Table 9: Nuclei troubleshooting log 19
Table 10: Nuclei critical and high results (grouped) 22
Table 11: Risk assessment table (lab format) - all findings 23
Table 12: Remediation phases, findings and target dates 29
Table 13: Limitations 29
Table 14: Evidence files 30
Table 15: Complete Nuclei output with severity and mapped finding 31
Table 16: Complete Nikto output with category and mapped finding 34
Table 17: Commands used in the lab 36

## List of figures

Figure 1: Working directory created and Nmap 7.95 and Nikto 2.5.0 versions confirmed 5
Figure 2: Nuclei not found; installed from the Kali repository (3.11.1-0kali1) 6
Figure 3: Nuclei engine v3.11.1 and xsltproc versions confirmed 6
Figure 4: Target console: DHCP lease for 192.168.164.129 and ifconfig eth1 output on metasploitable 7
Figure 5: Kali network configuration (eth1 192.168.164.128/24) and ping to the target 8
Figure 6: Nmap output, part 1: FTP (21), SSH (22), Telnet (23), SMTP with SSLv2 (25), DNS (53) 9
Figure 7: Nmap output, part 2: HTTP (80), rpcbind, Samba, r-services, RMI, bind shell, NFS, ProFTPD, MySQL, distccd, PostgreSQL, VNC 10
Figure 8: Nmap output, part 3: VNC, X11, IRC, AJP, Tomcat, DRb, RPC and RMI ports, OS detection 11
Figure 9: Evidence files listed, HTML report generated with xsltproc and opened in Firefox 11
Figure 10: Nmap HTML report: scan summary, address, port table start and FTP anonymous login 12
Figure 11: Nmap HTML report: SSH, Telnet, SMTP (SSLv2 and certificate), DNS and HTTP 12
Figure 12: Nmap HTML report: rpcinfo, Samba, r-services, RMI, bind shell, NFS, ProFTPD, MySQL, distccd and PostgreSQL 13
Figure 13: Nmap HTML report: VNC, X11, IRC, AJP and Tomcat 13
Figure 14: Nmap HTML report: DRb, RPC and RMI ports, OS detection and host script output 14
Figure 15: Nmap HTML report: nbstat host script output (NetBIOS name METASPLOITABLE) 14
Figure 16: Nikto 2.5.0 scan of http://192.168.164.129 (27 items reported, 52 seconds, 8,910 requests) 17
Figure 17: Nikto output file viewed with less 17
Figure 18: nikto_scan.txt saved (3.4 KB) 17
Figure 19: Nuclei version, template update and the first scan failing with "no templates provided for scan" 19
Figure 20: Template update debug log: context deadline exceeded 19
Figure 21: Evidence folder: nuclei_scan.txt is 0 bytes and nuclei_template_update.txt is 468 bytes 20
Figure 22: Connectivity test to GitHub: HTTP/2 302 redirect to the latest release 20
Figure 23: nuclei -update-templates -timeout 30 20
Figure 24: nuclei -tv shows no template version 20
Figure 25: Template directory empty: no YAML files 21
Figure 26: Workaround: git clone of nuclei-templates (14,474 files) 21
Figure 27: Nuclei results by scanner severity label 22
Figure 28: Assessed findings by inherent risk rating 26
Figure 29: Heat map of findings by likelihood and impact 27

# 1. Introduction and Objectives

## 1.1 Purpose

In this lab I acted as an internal auditor conducting a technical assessment on a newly discovered test server (Metasploitable) in the company's development environment. The aim goes beyond finding technical flaws: it is to understand their impact on the organisation's risk posture and compliance status, and to translate technical findings into business risk and compliance terms for management.

## 1.2 Objectives

1. Discover live hosts and identify open ports and services.
2. Enumerate software versions and identify known vulnerabilities.
3. Analyse findings and map them to common compliance frameworks (NIST, CIS, PCI DSS).
4. Assess the risk level of each finding.
5. Document results in a structured, professional format, including visual reports.

## 1.3 Approach and structure

The report follows the three phases and seven steps in the lab brief. Each step shows the command, the screenshot evidence, what the output means and its GRC context. Every figure and table is numbered and listed at the front. The complete findings are in the companion vulnerability report and Excel register.

**Table 1:** *Lab steps mapped to report sections*

| Phase | Lab step | Report section |
|---|---|---|
| 1 Discovery and enumeration | Step 1 Network discovery (ping) | 3.1 |
| | Step 2 Port and service enumeration (Nmap) | 3.2 |
| 2 Vulnerability identification | Step 3 Analysing Nmap output | 4.1 |
| | Step 4 Web application assessment (Nikto) | 4.2 |
| | Step 5 Focused scanning (Nuclei) | 4.3 |
| 3 Analysis and reporting | Step 6 Triage and risk assessment | 5.1 |
| | Step 7 Executive summary | 5.2 |

## 1.4 Deliverables checklist

**Table 2:** *Lab deliverables and where they are covered*

| # | Deliverable required by the lab | Status | Where |
|---|---|---|---|
| 1 | Nmap output files (initial_scan.nmap, initial_scan.xml) | Produced (plus .gnmap) | Figure 9; Appendix C; Section 9 |
| 2 | Screenshot of the Nmap HTML report | Included | Figures 10-15 |
| 3 | Nikto and Nuclei scan outputs | Included | Sections 4.2, 4.3; Appendices A, B |
| 4 | Completed risk assessment table | Completed (38 findings) | Section 5.1 |
| 5 | Executive summary | Completed | Section 5.2 |

# 2. Lab Environment and Setup

**Table 3:** *Lab environment*

| Item | Detail |
|---|---|
| Attacker machine | Kali Linux (rolling), IP 192.168.164.128/24, interface eth1, MAC 00:0c:29:fd:c8:54 |
| Target machine | Metasploitable, IP 192.168.164.129, MAC 00:0C:29:5B:0B:68 (VMware), hostname metasploitable; address by DHCP from 192.168.164.254 |
| Network | 192.168.164.0/24 (same subnet, no intervening firewall tested) |
| Working folder | ~/grc-lab1/evidence |
| Tools and versions | Nmap 7.95 (libpcap 1.10.5, openssl 3.5.4); Nikto 2.5.0; Nuclei v3.11.1 (installed as 3.11.1-0kali1); xsltproc (libxml 21406, libxslt 10143); git 2.51.0 |

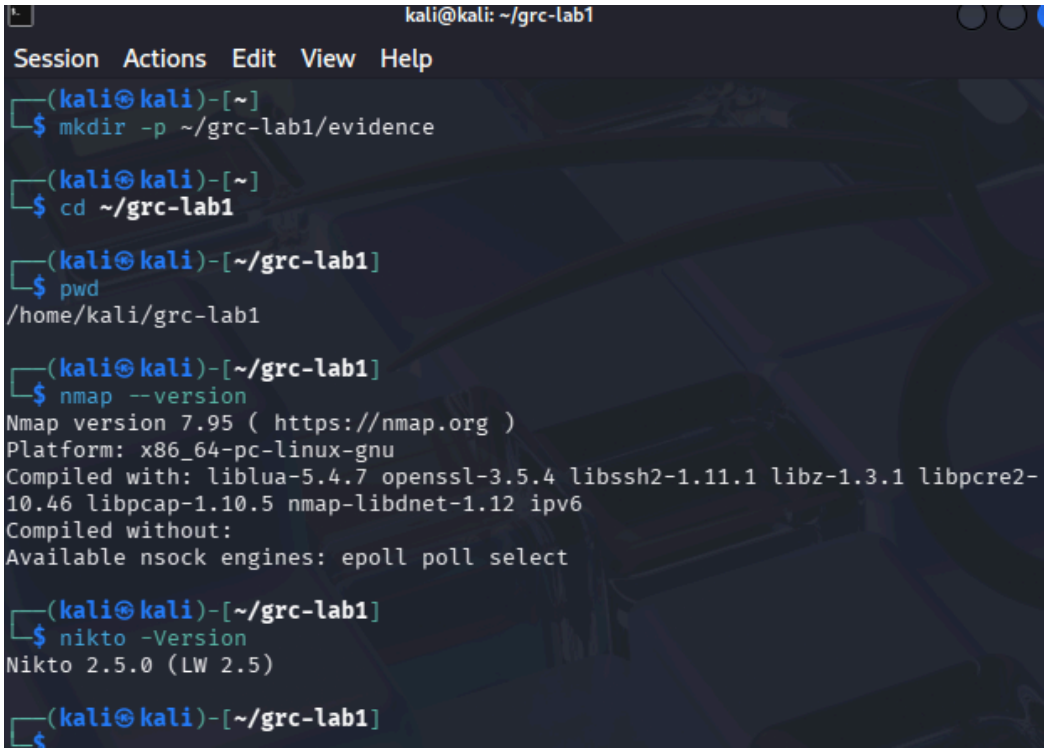



**Figure 1:** *Working directory created and Nmap 7.95 and Nikto 2.5.0 versions confirmed*

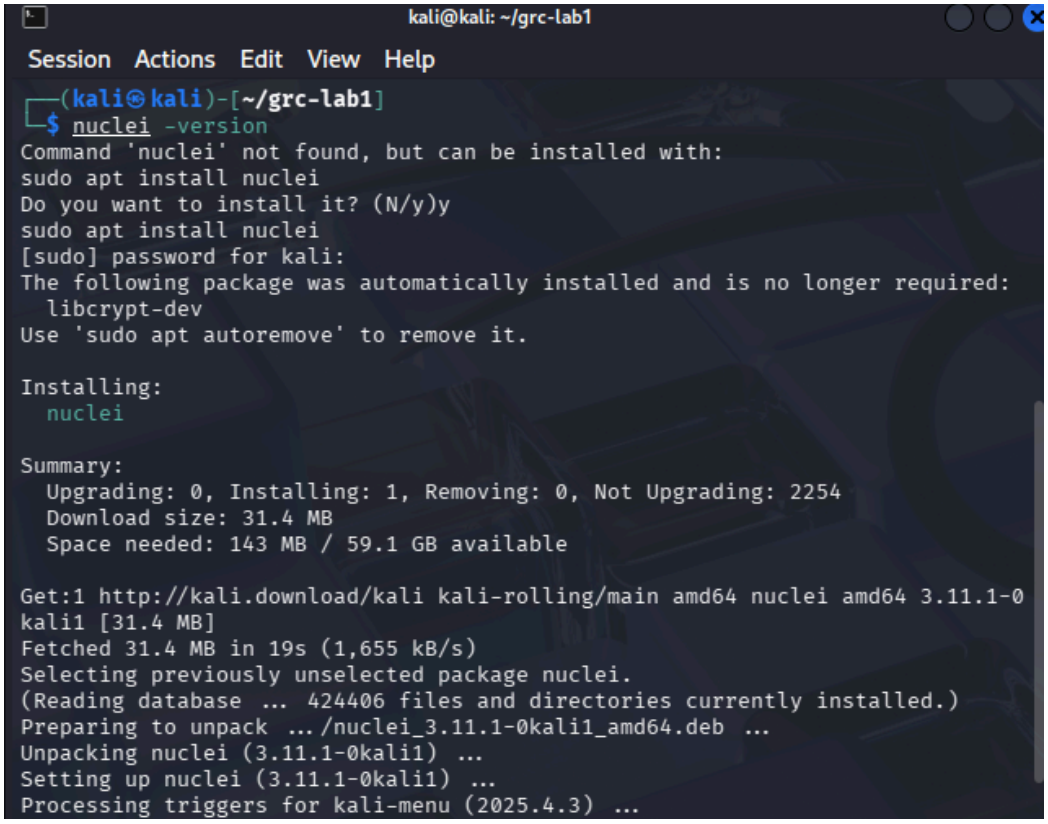



**Figure 2:** *Nuclei not found; installed from the Kali repository (3.11.1-0kali1)*

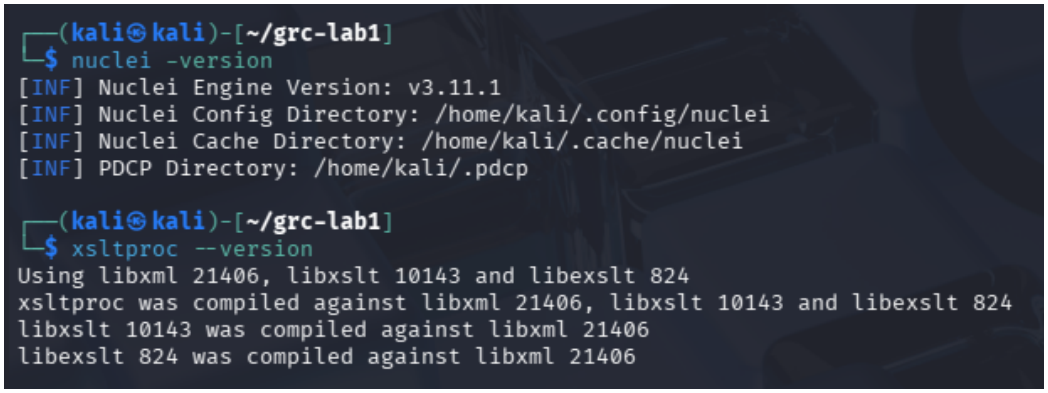



**Figure 3:** *Nuclei engine v3.11.1 and xsltproc versions confirmed*




**Figure 4:** *Target console: DHCP lease for 192.168.164.129 and ifconfig eth1 output on metasploitable*

# 3. Phase 1: Discovery and Enumeration

## 3.1 Step 1: Network discovery

**Task:** confirm the target is alive and identify its IP address.

```
ping -c 4 192.168.164.129
```

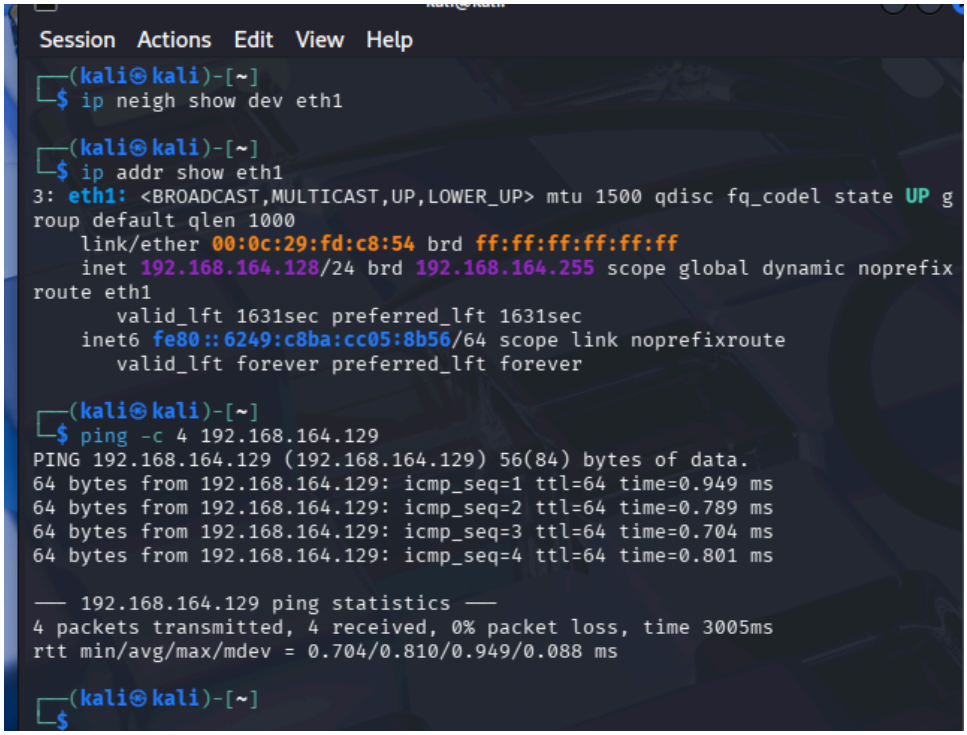



**Figure 5:** *Kali network configuration (eth1 192.168.164.128/24) and ping to the target*

**Result:** 4 packets transmitted, 4 received, 0% packet loss; round-trip min/avg/max/mdev 0.704/0.810/0.949/0.088 ms; TTL 64 (typical of Linux). The host is alive and reachable on the same Layer 2 segment.

> **GRC context:** this step supports asset inventory management, a requirement of NIST CSF (ID.AM-1 in CSF 1.1, ID.AM-01 in CSF 2.0) and CIS Control 1. A host that is not in the inventory cannot be protected, patched or assessed. The inventory record for this server should show an owner, purpose and environment.

## 3.2 Step 2: Port and service enumeration with Nmap

**Task:** run a comprehensive scan to identify all open ports, services and versions.

```
nmap -sV -sC -O -p- -oA evidence/initial_scan 192.168.164.129
```

**Table 4:** *Nmap options used*

| Option | Purpose |
|---|---|
| `-sV` | Probe open ports to determine service and version information |

| Option | Purpose |
|---|---|
| `-sC` | Run the default (safe) Nmap scripts for discovery |
| `-O` | Enable operating system detection |
| `-p-` | Scan all 65,535 TCP ports |
| `-oA evidence/initial_scan` | Save normal (.nmap), grepable (.gnmap) and XML (.xml) output |

The scan started at 04:57:27 EDT on 22 October 2026 and finished at 05:00:32 (184.73 seconds). The host was up with 0.0011 s latency; 65,505 ports were closed (reset) and 30 were open. Nmap identified the OS as Linux 2.6.9 - 2.6.33 (100%).

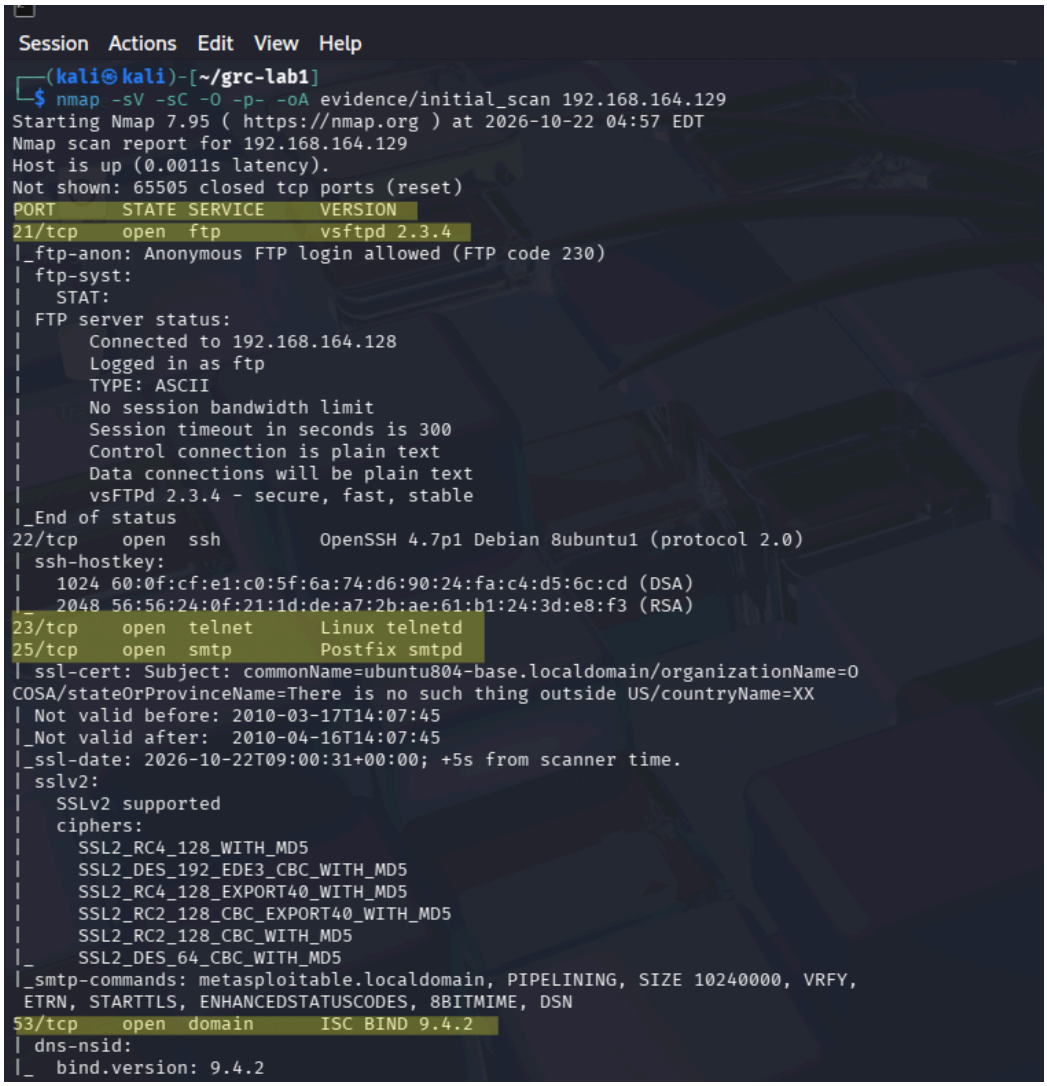



**Figure 6:** *Nmap output, part 1: FTP (21), SSH (22), Telnet (23), SMTP with SSLv2 (25), DNS (53)*

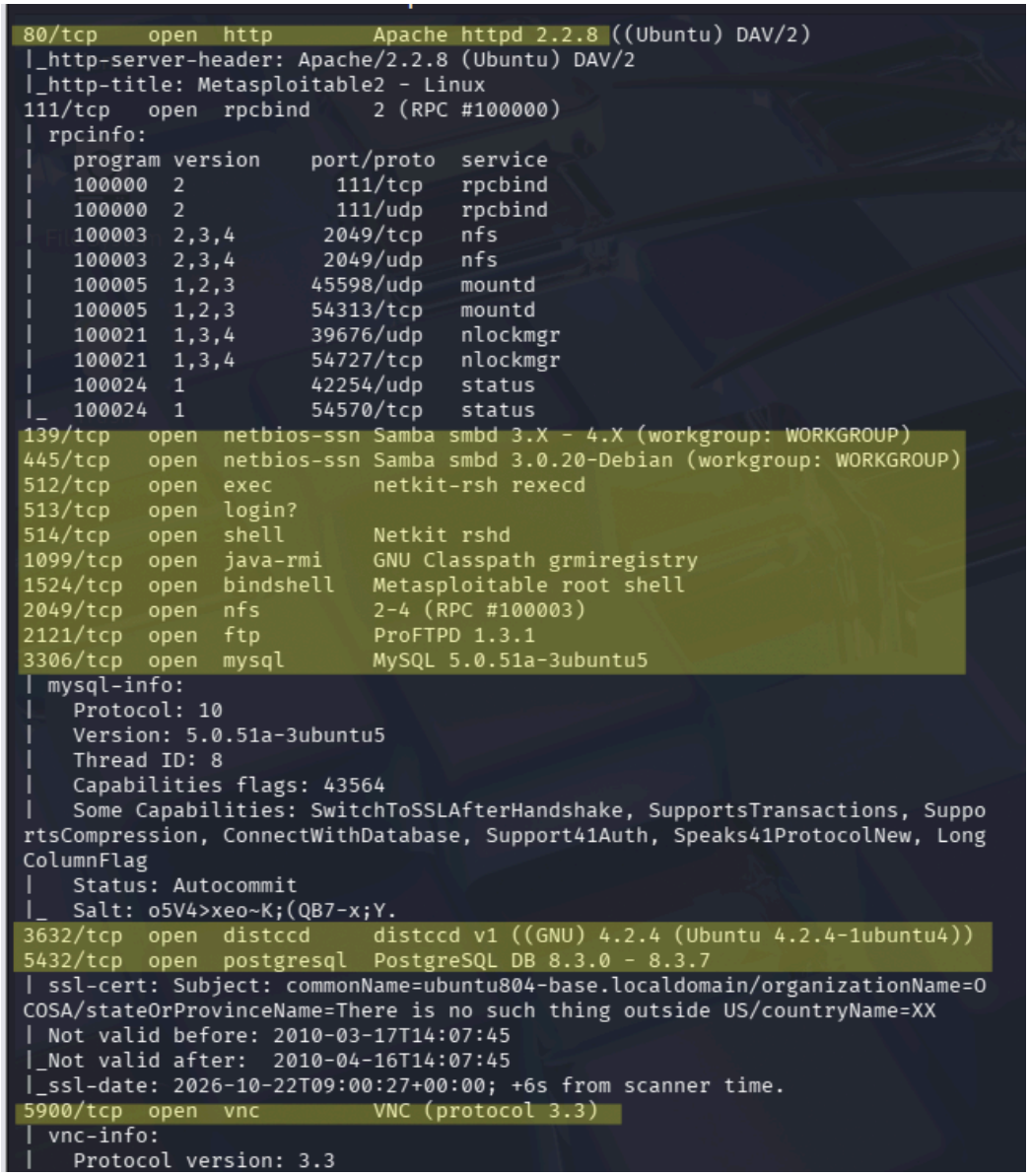



**Figure 7:** *Nmap output, part 2: HTTP (80), rpcbind, Samba, r-services, RMI, bind shell, NFS, ProFTPD, MySQL, distccd, PostgreSQL, VNC*

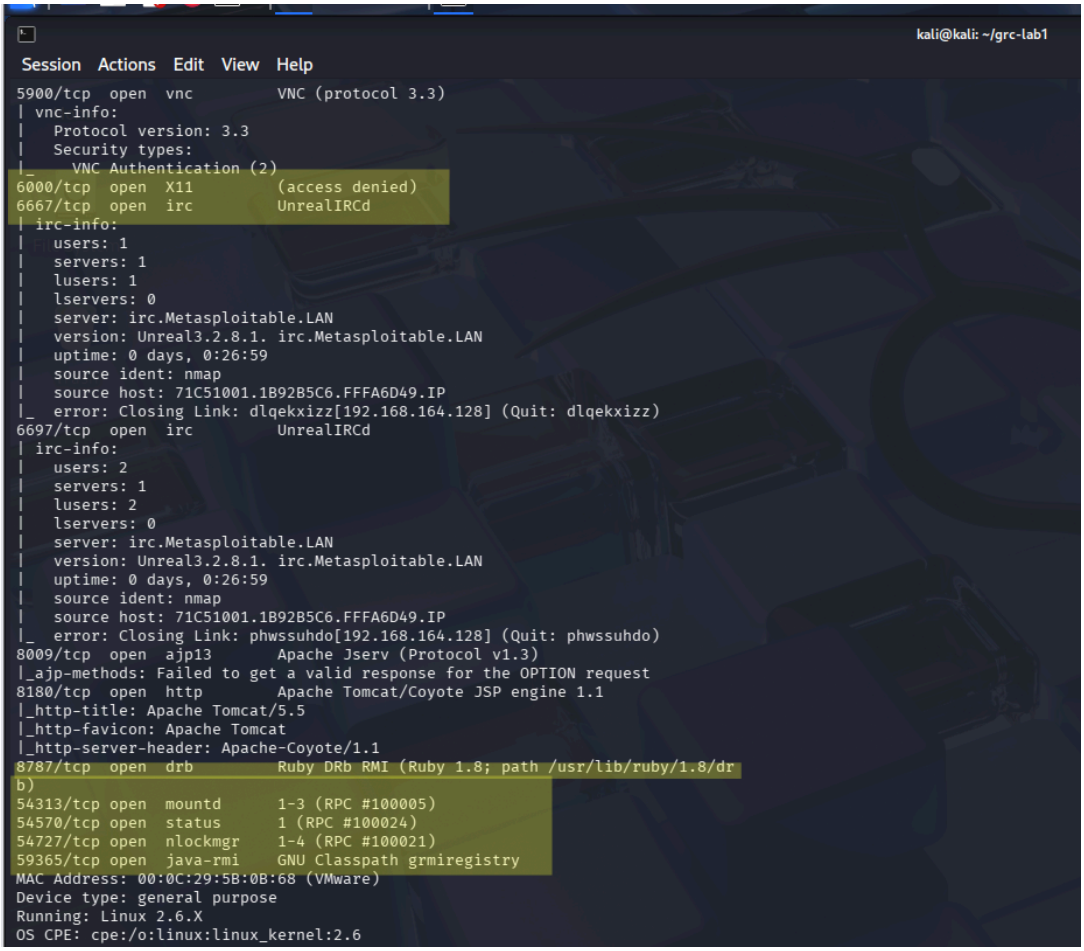



**Figure 8:** *Nmap output, part 3: VNC, X11, IRC, AJP, Tomcat, DRb, RPC and RMI ports, OS detection*

The scan saved three files inside the evidence folder: initial_scan.nmap (readable results), initial_scan.xml (data for the HTML report) and initial_scan.gnmap (grep-friendly results). The XML file was converted to an HTML report with xsltproc and opened in Firefox.

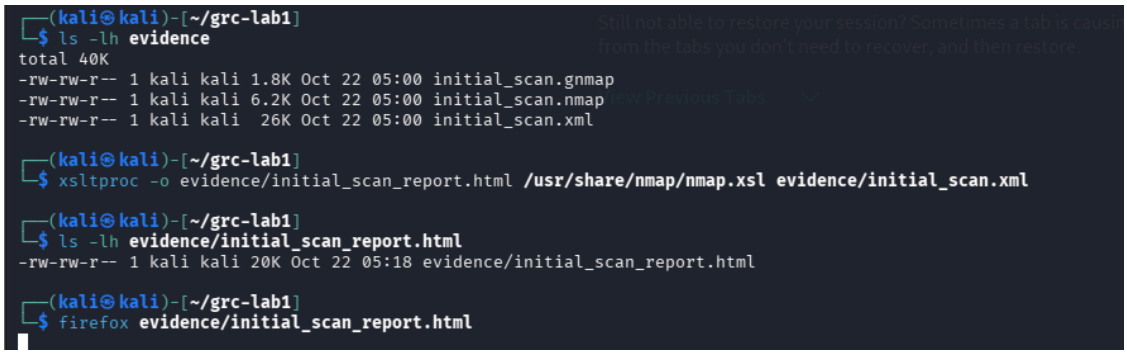
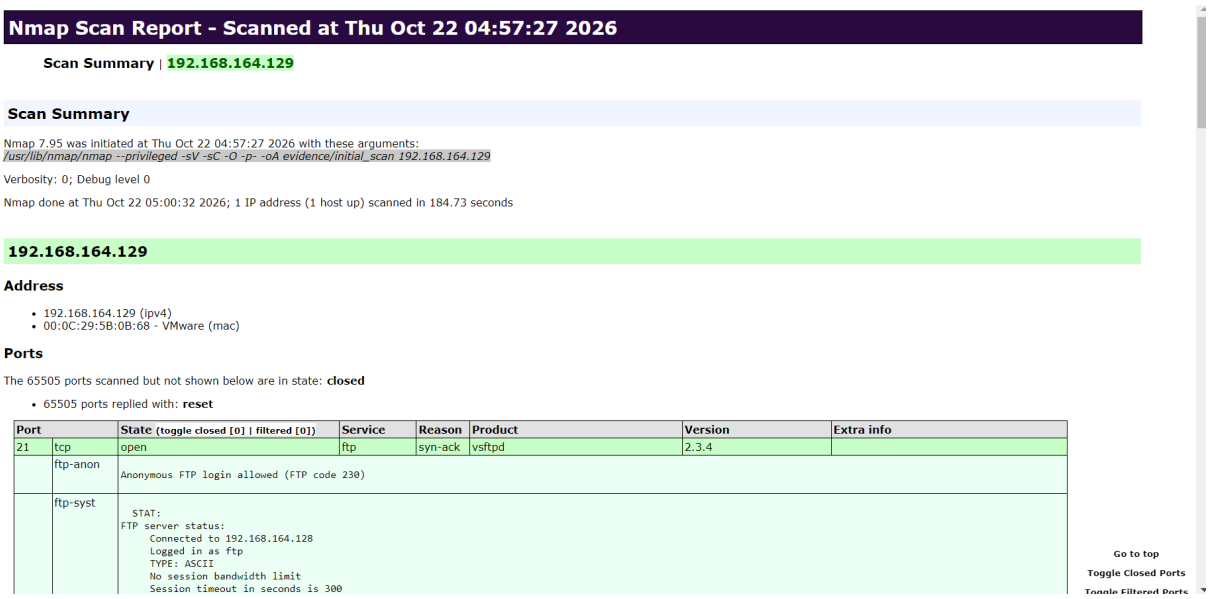



**Figure 9:** *Evidence files listed, HTML report generated with xsltproc and opened in Firefox*

## Nmap HTML report



**Nmap Scan Report - Scanned at Thu Oct 22 04:57:27 2026**

Scan Summary | 192.168.164.129

**Scan Summary**

Nmap 7.95 was initiated at Thu Oct 22 04:57:27 2026 with these arguments:
*/usr/lib/nmap/nmap --privileged -sV -sC -O -p- -oA evidence/initial_scan 192.168.164.129*

Verbosity: 0; Debug level 0

Nmap done at Thu Oct 22 05:00:32 2026; 1 IP address (1 host up) scanned in 184.73 seconds

**192.168.164.129**

**Address**

- 192.168.164.129 (ipv4)
- 00:0C:29:5B:0B:68 - VMware (mac)

**Ports**

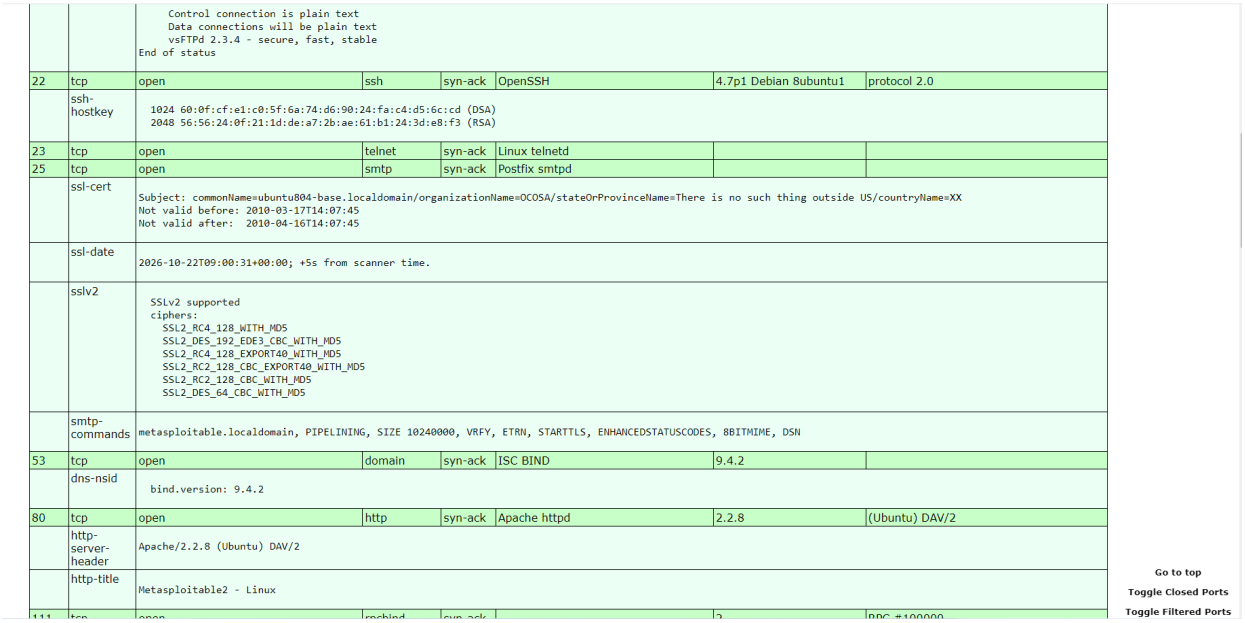
The 65505 ports scanned but not shown below are in state: **closed**

- 65505 ports replied with: **reset**

| Port | | State (toggle closed [0] \| filtered [0]) | Service | Reason | Product | Version | Extra info |
|---|---|---|---|---|---|---|---|
| 21 | tcp | open | ftp | syn-ack | vsftpd | 2.3.4 | |
| | ftp-anon | Anonymous FTP login allowed (FTP code 230) | | | | | |
| | ftp-syst | STAT:<br>FTP server status:<br>Connected to 192.168.164.128<br>Logged in as ftp<br>TYPE: ASCII<br>No session bandwidth limit<br>Session timeout in seconds is 300 | | | | | |

Go to top
Toggle Closed Ports
Toggle Filtered Ports

**Figure 10:** *Nmap HTML report: scan summary, address, port table start and FTP anonymous login*



| | | | | | | | |
|---|---|---|---|---|---|---|---|
| | | Control connection is plain text<br>Data connections will be plain text<br>vsFTPd 2.3.4 - secure, fast, stable<br>End of status | | | | | |
| 22 | tcp | open | ssh | syn-ack | OpenSSH | 4.7p1 Debian 8ubuntu1 | protocol 2.0 |
| | ssh-hostkey | 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)<br>2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA) | | | | | |
| 23 | tcp | open | telnet | syn-ack | Linux telnetd | | |
| 25 | tcp | open | smtp | syn-ack | Postfix smtpd | | |
| | ssl-cert | Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX<br>Not valid before: 2010-03-17T14:07:45<br>Not valid after: 2010-04-16T14:07:45 | | | | | |
| | ssl-date | 2026-10-22T09:00:31+00:00; +5s from scanner time. | | | | | |
| | sslv2 | SSLv2 supported<br>ciphers:<br>SSL2_RC4_128_WITH_MD5<br>SSL2_DES_192_EDE3_CBC_WITH_MD5<br>SSL2_RC4_128_EXPORT40_WITH_MD5<br>SSL2_RC2_128_CBC_EXPORT40_WITH_MD5<br>SSL2_RC2_128_CBC_WITH_MD5<br>SSL2_DES_64_CBC_WITH_MD5 | | | | | |
| | smtp-commands | metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN | | | | | |
| 53 | tcp | open | domain | syn-ack | ISC BIND | 9.4.2 | |
| | dns-nsid | bind.version: 9.4.2 | | | | | |
| 80 | tcp | open | http | syn-ack | Apache httpd | 2.2.8 | (Ubuntu) DAV/2 |
| | http-server-header | Apache/2.2.8 (Ubuntu) DAV/2 | | | | | |
| | http-title | Metasploitable2 - Linux | | | | | |
| 111 | tcp | open | rpcbind | syn-ack | | 2 | RPC #100000 |

Go to top
Toggle Closed Ports
Toggle Filtered Ports

**Figure 11:** *Nmap HTML report: SSH, Telnet, SMTP (SSLv2 and certificate), DNS and HTTP*

| | | | | | | | |
|---|---|---|---|---|---|---|---|
| 111 | tcp | open | rpcbind | syn-ack | | 2 | RPC #100000 |
| | rpcinfo | program version port/proto service<br>100000 2 111/tcp rpcbind<br>100000 2 111/udp rpcbind<br>100003 2,3,4 2049/tcp nfs<br>100003 2,3,4 2049/udp nfs<br>100005 1,2,3 45598/udp mountd<br>100005 1,2,3 54313/tcp mountd<br>100021 1,3,4 39676/udp nlockmgr<br>100021 1,3,4 54727/tcp nlockmgr<br>100024 1 42254/udp status<br>100024 1 54570/tcp status | | | | | |
| 139 | tcp | open | netbios-ssn | syn-ack | Samba smbd | 3.X - 4.X | workgroup: WORKGROUP |
| 445 | tcp | open | netbios-ssn | syn-ack | Samba smbd | 3.0.20-Debian | workgroup: WORKGROUP |
| 512 | tcp | open | exec | syn-ack | netkit-rsh rexecd | | |
| 513 | tcp | open | login | syn-ack | | | |
| 514 | tcp | open | shell | syn-ack | Netkit rshd | | |
| 1099 | tcp | open | java-rmi | syn-ack | GNU Classpath grmiregistry | | |
| 1524 | tcp | open | bindshell | syn-ack | Metasploitable root shell | | |
| 2049 | tcp | open | nfs | syn-ack | | 2-4 | RPC #100003 |
| 2121 | tcp | open | ftp | syn-ack | ProFTPD | 1.3.1 | |
| 3306 | tcp | open | mysql | syn-ack | MySQL | 5.0.51a-3ubuntu5 | |
| | mysql-info | Protocol: 10<br>Version: 5.0.51a-3ubuntu5<br>Thread ID: 8<br>Capabilities flags: 43564<br>Some Capabilities: SwitchToSSLAfterHandshake, SupportsTransactions, SupportsCompression, ConnectWithDatabase, Support41Auth, Speaks41ProtocolNew, LongColumnFlag<br>Status: Autocommit<br>Salt: o5V4>xeo~K;(QB7-x;Y. | | | | | |
| 3632 | tcp | open | distccd | syn-ack | distccd | v1 | (GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4) |
| 5432 | tcp | open | postgresql | syn-ack | PostgreSQL DB | 8.3.0 - 8.3.7 | |
| | ssl-cert | Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX<br>Not valid before: 2010-03-17T14:07:45<br>Not valid after: 2010-04-16T14:07:45 | | | | | |

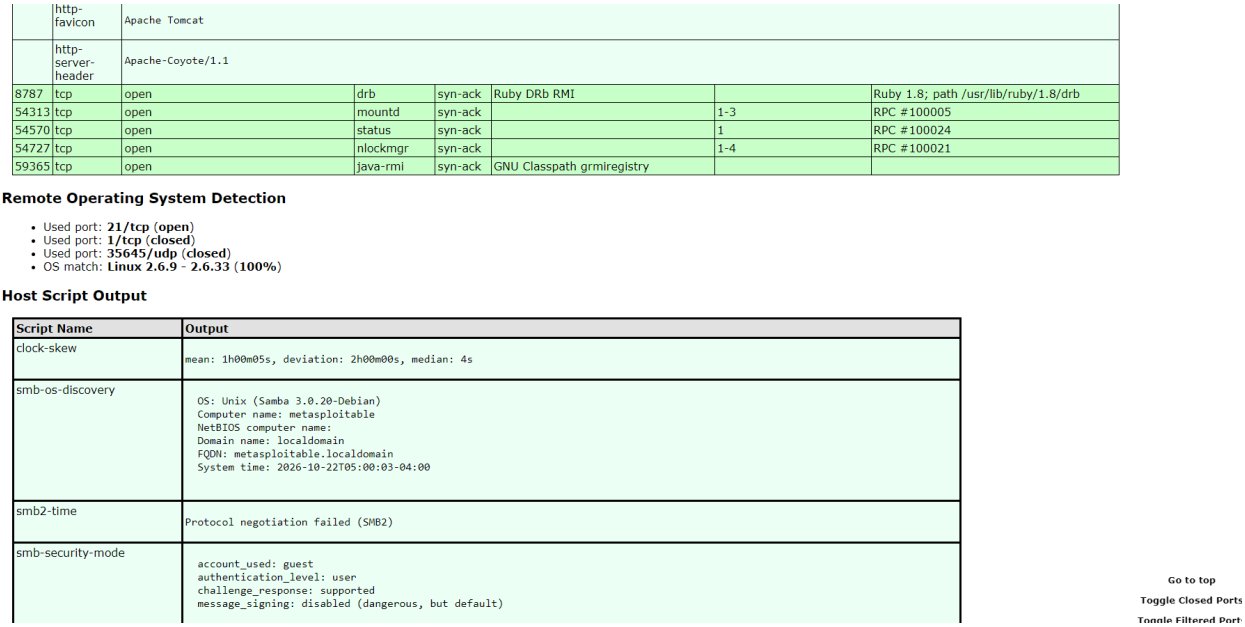
Go to top
Toggle Closed Ports
Toggle Filtered Ports

**Figure 12:** *Nmap HTML report: rpcinfo, Samba, r-services, RMI, bind shell, NFS, ProFTPD, MySQL, distccd and PostgreSQL*

| | | | | | | | |
|---|---|---|---|---|---|---|---|
| | ssl-date | 2026-10-22T09:00:27+00:00; +6s from scanner time. | | | | | |
| 5900 | tcp | open | vnc | syn-ack | VNC | | protocol 3.3 |
| | vnc-info | Protocol version: 3.3<br>Security types:<br>VNC Authentication (2) | | | | | |
| 6000 | tcp | open | X11 | syn-ack | | | access denied |
| 6667 | tcp | open | irc | syn-ack | UnrealIRCd | | |
| | irc-info | users: 1<br>servers: 1<br>lusers: 1<br>lservers: 0<br>server: irc.Metasploitable.LAN<br>version: Unreal3.2.8.1. irc.Metasploitable.LAN<br>uptime: 0 days, 0:26:59<br>source ident: nmap<br>source host: 71C51001.1B92B5C6.FFFA6D49.IP<br>error: Closing Link: dlqekxizz[192.168.164.128] (Quit: dlqekxizz) | | | | | |
| 6697 | tcp | open | irc | syn-ack | UnrealIRCd | | |
| | irc-info | users: 2<br>servers: 1<br>lusers: 2<br>lservers: 0<br>server: irc.Metasploitable.LAN<br>version: Unreal3.2.8.1. irc.Metasploitable.LAN<br>uptime: 0 days, 0:26:59<br>source ident: nmap<br>source host: 71C51001.1B92B5C6.FFFA6D49.IP<br>error: Closing Link: phwssuhdo[192.168.164.128] (Quit: phwssuhdo) | | | | | |
| 8009 | tcp | open | ajp13 | syn-ack | Apache Jserv | | Protocol v1.3 |
| | ajp-methods | Failed to get a valid response for the OPTION request | | | | | |
| 8180 | tcp | open | http | syn-ack | Apache Tomcat/Coyote JSP engine | 1.1 | |
| | http-title | Apache Tomcat/5.5 | | | | | |

Go to top
Toggle Closed Ports

**Figure 13:** *Nmap HTML report: VNC, X11, IRC, AJP and Tomcat*



| | | | | | | | |
|---|---|---|---|---|---|---|---|
| | http-favicon | Apache Tomcat | | | | | |
| | http-server-header | Apache-Coyote/1.1 | | | | | |
| 8787 | tcp | open | drb | syn-ack | Ruby DRb RMI | | Ruby 1.8; path /usr/lib/ruby/1.8/drb |
| 54313 | tcp | open | mountd | syn-ack | | 1-3 | RPC #100005 |
| 54570 | tcp | open | status | syn-ack | | 1 | RPC #100024 |
| 54727 | tcp | open | nlockmgr | syn-ack | | 1-4 | RPC #100021 |
| 59365 | tcp | open | java-rmi | syn-ack | GNU Classpath grmiregistry | | |

**Remote Operating System Detection**

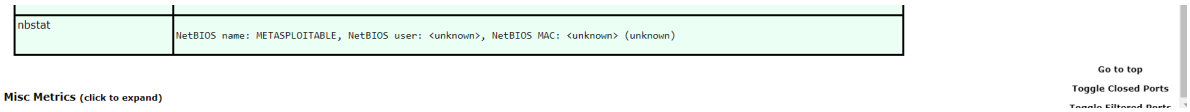
- Used port: **21/tcp** (**open**)
- Used port: **1/tcp** (**closed**)
- Used port: **35645/udp** (**closed**)
- OS match: **Linux 2.6.9 - 2.6.33** (**100%**)

**Host Script Output**

| Script Name | Output |
|---|---|
| clock-skew | mean: 1h00m05s, deviation: 2h00m00s, median: 4s |
| smb-os-discovery | OS: Unix (Samba 3.0.20-Debian)<br>Computer name: metasploitable<br>NetBIOS computer name:<br>Domain name: localdomain<br>FQDN: metasploitable.localdomain<br>System time: 2026-10-22T05:00:03-04:00 |
| smb2-time | Protocol negotiation failed (SMB2) |
| smb-security-mode | account_used: guest<br>authentication_level: user<br>challenge_response: supported<br>message_signing: disabled (dangerous, but default) |

Go to top
Toggle Closed Ports
Toggle Filtered Ports

**Figure 14:** *Nmap HTML report: DRb, RPC and RMI ports, OS detection and host script output*



| | |
|---|---|
| nbstat | NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown) |

**Misc Metrics** (click to expand)

Go to top
Toggle Closed Ports
Toggle Filtered Ports

**Figure 15:** *Nmap HTML report: nbstat host script output (NetBIOS name METASPLOITABLE)*

## What the scan found: open port inventory

**Table 5:** *All 30 open TCP ports with initial security concern and related findings*

| Port | Service identified | Initial security concern | Findings |
|---|---|---|---|
| **21/tcp** | vsftpd 2.3.4 | Anonymous FTP login permitted; cleartext; backdoor version | R01, R10 |
| **22/tcp** | OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0) | Legacy version; 1024-bit DSA host key | R26 |
| **23/tcp** | Linux telnetd | Credentials transmitted without encryption | R08 |
| **25/tcp** | Postfix smtpd | SSLv2 supported; obsolete protocol; expired certificate | R18, R31, R32 |
| **53/tcp** | ISC BIND 9.4.2 | Legacy version; needs verification | R27 |
| **80/tcp** | Apache httpd 2.2.8 ((Ubuntu) DAV/2) | Legacy web server and PHP; test and admin paths | R13, R14, R22-R25, R33-R35 |
| **111/tcp** | RPC #100000 v2 | RPC portmapper exposes NFS/mountd/status | R21, R38 |
| **139/tcp** | Samba smbd 3.X - 4.X (WORKGROUP) | Legacy file sharing (NetBIOS session) | R12 |
| **445/tcp** | Samba smbd 3.0.20-Debian (WORKGROUP) | Legacy Samba; guest access; signing disabled | R11, R12 |
| **512/tcp** | netkit-rsh rexecd | Legacy r-service (rexec) | R09 |
| **513/tcp** | (unidentified) | Legacy r-service (rlogin) | R09 |
| **514/tcp** | Netkit rshd | Legacy r-service (rsh) | R09 |
| **1099/tcp** | GNU Classpath grmiregistry | Remote Java registry exposed | R29 |
| **1524/tcp** | Metasploitable root shell | Nmap identifies a Metasploitable root shell | R02 |
| **2049/tcp** | RPC #100003 v2-4 | NFS exposed; exports not checked | R21 |
| **2121/tcp** | ProFTPD 1.3.1 | Legacy second FTP service | R28 |
| **3306/tcp** | MySQL 5.0.51a-3ubuntu5 | Legacy database exposed on the network | R15 |
| **3632/tcp** | distccd v1 ((GNU) 4.2.4 Ubuntu 4.2.4-1ubuntu4) | Remote compilation service exposed | R05 |

| Port | Service identified | Initial security concern | Findings |
|---|---|---|---|
| **5432/tcp** | PostgreSQL DB 8.3.0 - 8.3.7 | Legacy database exposed; default credentials | R03, R15, R31 |
| **5900/tcp** | VNC (protocol 3.3) | Remote desktop exposed; weak passwords | R06 |
| **6000/tcp** | (access denied) | Remote graphical service exposed (access denied) | R37 |
| **6667/tcp** | UnrealIRCd 3.2.8.1 | IRC service; version 3.2.8.1 needs validation | R07 |
| **6697/tcp** | UnrealIRCd 3.2.8.1 | IRC service; version 3.2.8.1 needs validation | R07 |
| **8009/tcp** | Apache Jserv (Protocol v1.3) | Apache JServ connector exposed (Ghostcat) | R04 |
| **8180/tcp** | Apache Tomcat/Coyote JSP engine 1.1 | Legacy Tomcat 5.5 application server | R17 |
| **8787/tcp** | Ruby DRb RMI (Ruby 1.8) | Ruby DRb remote objects exposed | R16 |
| **54313/tcp** | RPC #100005 v1-3 | RPC mountd helper port | R21 |
| **54570/tcp** | RPC #100024 v1 | RPC status helper port | R21 |
| **54727/tcp** | RPC #100021 v1-4 | RPC lock manager helper port | R21 |
| **59365/tcp** | GNU Classpath grmiregistry | Remote Java registry exposed | R29 |

These are initial observations, not all confirmed exploitable vulnerabilities. I validated findings before assigning final severity and risk ratings.

### GRC question: why is knowing which ports are open a compliance issue?

Ports such as 21/FTP and 23/Telnet matter for compliance, not only for security, because:

- **Attack surface reduction:** frameworks require only necessary services, ports and protocols to be enabled (CIS 4.8, 12.2; NIST CSF PR.PS-01, formerly PR.IP-1; ISO 27001 A.8.9; PCI DSS 2.2.4). This host had 30 open ports and none filtered.
- **Cleartext protocols:** FTP and Telnet send credentials unencrypted, which conflicts with data-in-transit requirements (NIST CSF PR.DS-02; CIS 3.10, 12.6; PCI DSS 2.2.7, 4.2.1).
- **Accountability:** every open port should have an owner, purpose and approval in the asset inventory (CIS 1.1; NIST CSF ID.AM-01).
- **Vulnerability management:** version banners on open ports feed patching and end-of-life tracking (CIS 7.1-7.7).
- **Audit evidence:** a dated port inventory with approved exceptions is the evidence an auditor will request. The lab brief cites CIS Control 9 (v7), now v8 safeguards 4.8, 12.2 and 13.4.

# 4. Phase 2: Vulnerability Identification

## 4.1 Step 3: Analysing the Nmap output

I reviewed initial_scan.nmap and the HTML report and noted every service and version for further analysis.

**Table 6:** *Service versions identified*

| Service | Version identified | Assessment |
|---|---|---|
| FTP | vsftpd 2.3.4; ProFTPD 1.3.1 | vsftpd 2.3.4 is the release with a known backdoor (CVE-2011-2523); ProFTPD is obsolete |
| SSH | OpenSSH 4.7p1 Debian 8ubuntu1 | End-of-life version; weak host key |
| Telnet | Linux telnetd | Cleartext protocol |
| SMTP | Postfix smtpd | SSLv2 and export ciphers; VRFY enabled |
| DNS | ISC BIND 9.4.2 | Obsolete |
| HTTP | Apache httpd 2.2.8 (Ubuntu) DAV/2; PHP 5.2.4 | End of life |
| SMB | Samba smbd 3.0.20-Debian | Obsolete; SMBv1 only |
| Databases | MySQL 5.0.51a-3ubuntu5; PostgreSQL 8.3.0 - 8.3.7 | Unsupported releases |
| Application servers | Apache Tomcat/Coyote 1.1 (Tomcat 5.5); Ruby DRb (Ruby 1.8); distccd v1 (GNU 4.2.4) | Unsupported or high-risk |
| IRC | UnrealIRCd (Unreal3.2.8.1) | Release known to have been trojaned; validate |
| Remote access | VNC (protocol 3.3); X11 | Weak authentication |

**Table 7:** *Interesting script outputs*

| Script | Output | Significance |
|---|---|---|
| ftp-anon | Anonymous FTP login allowed (FTP code 230) | Unauthenticated file access |
| ftp-syst | Control and data connections are plain text | Credentials exposed in transit |
| ssh-hostkey | 1024-bit DSA and 2048-bit RSA | DSA 1024 is weak |
| sslv2 | SSLv2 supported with six ciphers, including EXPORT40 and DES-64 | Broken protocol |
| ssl-cert | CN ubuntu804-base.localdomain; valid 2010-03-17 to 2010-04-16 | Certificate expired in 2010 |
| http-title | Metasploitable2 - Linux | Identifies a deliberately vulnerable image |
| smb-security-mode | account_used guest; message_signing disabled | Guest access and relay risk |
| vnc-info | Protocol 3.3; VNC Authentication (2) | Legacy authentication |
| irc-info | Unreal3.2.8.1 | Version of concern |
| clock-skew | mean 1h00m05s, deviation 2h00m00s | Time inconsistency |

## 4.2 Step 4: Web application assessment with Nikto

**Task:** scan the web server for common vulnerabilities, then inspect the applications manually.

```
nikto -h http://192.168.164.129 -output evidence/nikto_scan.txt
```

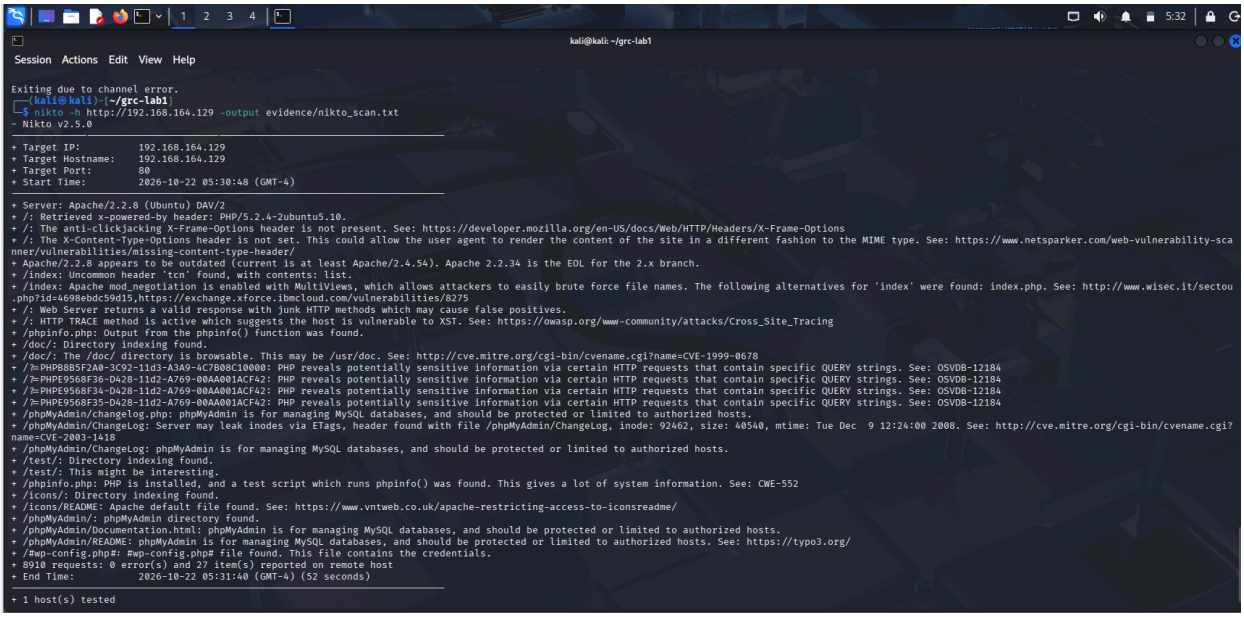



**Figure 16:** *Nikto 2.5.0 scan of http://192.168.164.129 (27 items reported, 52 seconds, 8,910 requests)*




**Figure 17:** *Nikto output file viewed with less*

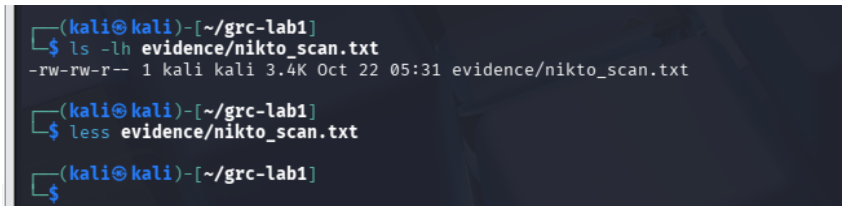



**Figure 18:** *nikto_scan.txt saved (3.4 KB)*

**Table 8:** *Nikto findings and why they matter*

| Finding | Why it matters |
|---|---|
| Outdated Apache 2.2.8 | An obsolete web-server version may contain known vulnerabilities. |
| Missing anti-clickjacking (X-Frame-Options) header | Users may be exposed to clickjacking attacks. |
| Missing X-Content-Type-Options header | Browsers may interpret content in unintended ways. |
| HTTP TRACE enabled | May increase exposure to cross-site tracing, depending on configuration. |
| Directory browsing enabled (/doc/, /test/, /icons/) | Visitors may list files in exposed directories. |
| /phpMyAdmin/ and database-management paths exposed | Administrative interfaces need access restrictions. |

| Finding | Why it matters |
|---|---|
| /test/ directory exposed | Test files or scripts may disclose information or introduce weaknesses. |
| /phpinfo.php exposed | Reveals PHP configuration and paths. |
| X-Powered-By: PHP/5.2.4-2ubuntu5.10; ETag inode leak | Reveals software versions and file system details. |
| '#wp-config.php#' reported | Possible credential file; unverified, check manually. |

**Manual inspection:** the lab asks for the site to be opened in Firefox to look for default pages and verbose errors. The Nmap http-title ("Metasploitable2 - Linux") and the Nikto paths show the default page and applications; no browser screenshot was captured, so add one here if the step was performed.

> **GRC context:** web applications are high-risk vectors. This aligns with the OWASP Top 10 (A05 Security Misconfiguration, A06 Vulnerable and Outdated Components) and PCI DSS Requirement 6 where the system is in scope.

The 27 Nikto items are listed in full in Appendix B.

## 4.3 Step 5: Focused vulnerability scanning with Nuclei

**Task:** use Nuclei to scan for known vulnerabilities based on the identified services.

```
nuclei -u http://192.168.164.129 -o evidence/nuclei_scan.txt
nuclei -target 192.168.164.129 -o evidence/nuclei_full_scan.txt   # lab brief, all services
```

### First attempt: no templates

After confirming the installed version, the first scan failed. Nuclei reported that its templates were not installed and outdated (latest v10.5.0), could not find the template directory, and stopped with "no templates provided for scan". The output file was created with 0 bytes. I recorded this as inconclusive, not as a clean scan.




**Figure 19:** *Nuclei version, template update and the first scan failing with "no templates provided for scan"*

## Troubleshooting

**Table 9:** *Nuclei troubleshooting log*

| Step | Action | Observation | Conclusion |
|---|---|---|---|
| 1 | nuclei -update-templates -debug 2>&1 \| tee evidence/nuclei_template_update.txt | failed to update nuclei templates: context deadline exceeded (Client.Timeout ... reading body) | Download timed out |
| 2 | ls -lh evidence | nuclei_scan.txt 0 bytes; nuclei_template_update.txt 468 bytes | Evidence of failed run saved |
| 3 | curl -I --max-time 15 https://github.com/projectdiscovery/nuclei-templates/releases/latest | HTTP/2 302 redirect to releases/tag/v10.5.0 | GitHub is reachable; not a general network outage |
| 4 | nuclei -update-templates -timeout 30 | Still reports templates outdated; no download | Longer timeout did not help |
| 5 | nuclei -tv; ls -lah ~/.local/nuclei-templates; find ... -name "*.yaml" | Version blank; directory empty; no YAML files | Template store empty |
| 6 | git clone --depth 1 https://github.com/projectdiscovery/nuclei-templates.git ~/nuclei-templates | Cloned 15,365 objects; 14,474 files updated | Templates obtained manually |
| 7 | Re-run Nuclei with the cloned templates | 59 results | Scan completed |

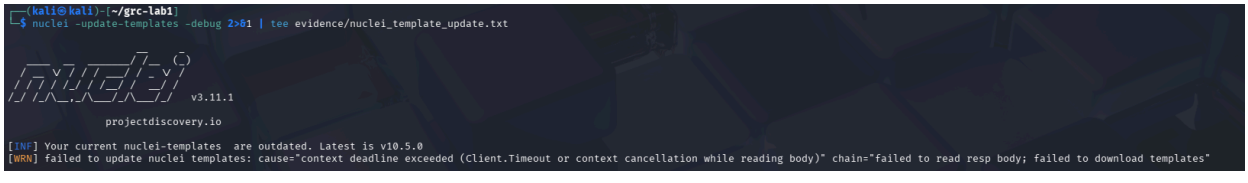



**Figure 20:** *Template update debug log: context deadline exceeded*

```
┌──(kali㉿kali)-[~/grc-lab1]
└─$ ls -lh evidence
total 152K
-rw-rw-r-- 1 kali kali 1.8K Oct 22 05:00  initial_scan.gnmap
-rw-rw-r-- 1 kali kali 6.2K Oct 22 05:00  initial_scan.nmap
-rw-rw-r-- 1 kali kali  20K Oct 22 05:18  initial_scan_report.html
-rw-rw-r-- 1 kali kali  26K Oct 22 05:00  initial_scan.xml
-rw-rw-r-- 1 kali kali 3.4K Oct 22 05:31  nikto_scan.txt
-rw-rw-r-- 1 kali kali  21K Oct 22 05:23 'Nmap Scan Report - Scanned at Thu Oct 22 04_57_27 2026.html'
-rw-rw-r-- 1 kali kali  59K Oct 22 05:22 'Nmap Scan Report - Scanned at Thu Oct 22 04_57_27 2026.pdf'
-rw-rw-r-- 1 kali kali    0 Oct 22 05:44  nuclei_scan.txt
-rw-rw-r-- 1 kali kali  468 Oct 22 05:46  nuclei_template_update.txt
```

**Figure 21:** *Evidence folder: nuclei_scan.txt is 0 bytes and nuclei_template_update.txt is 468 bytes*

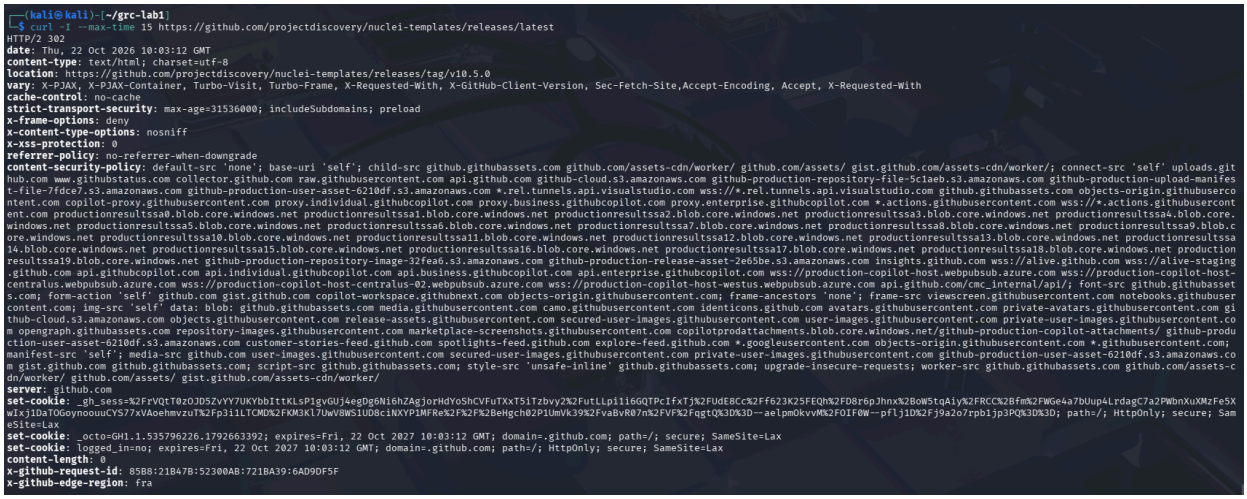



**Figure 22:** *Connectivity test to GitHub: HTTP/2 302 redirect to the latest release*

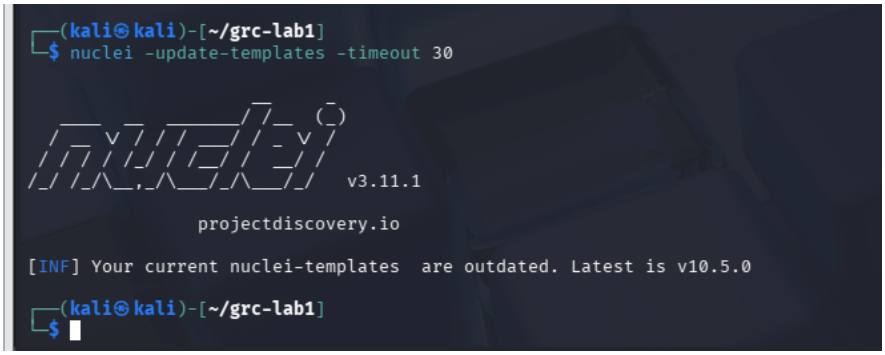



**Figure 23:** *nuclei -update-templates -timeout 30*




**Figure 24:** *nuclei -tv shows no template version*

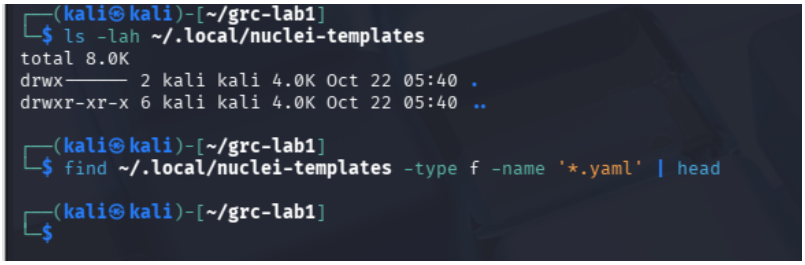



**Figure 25:** *Template directory empty: no YAML files*

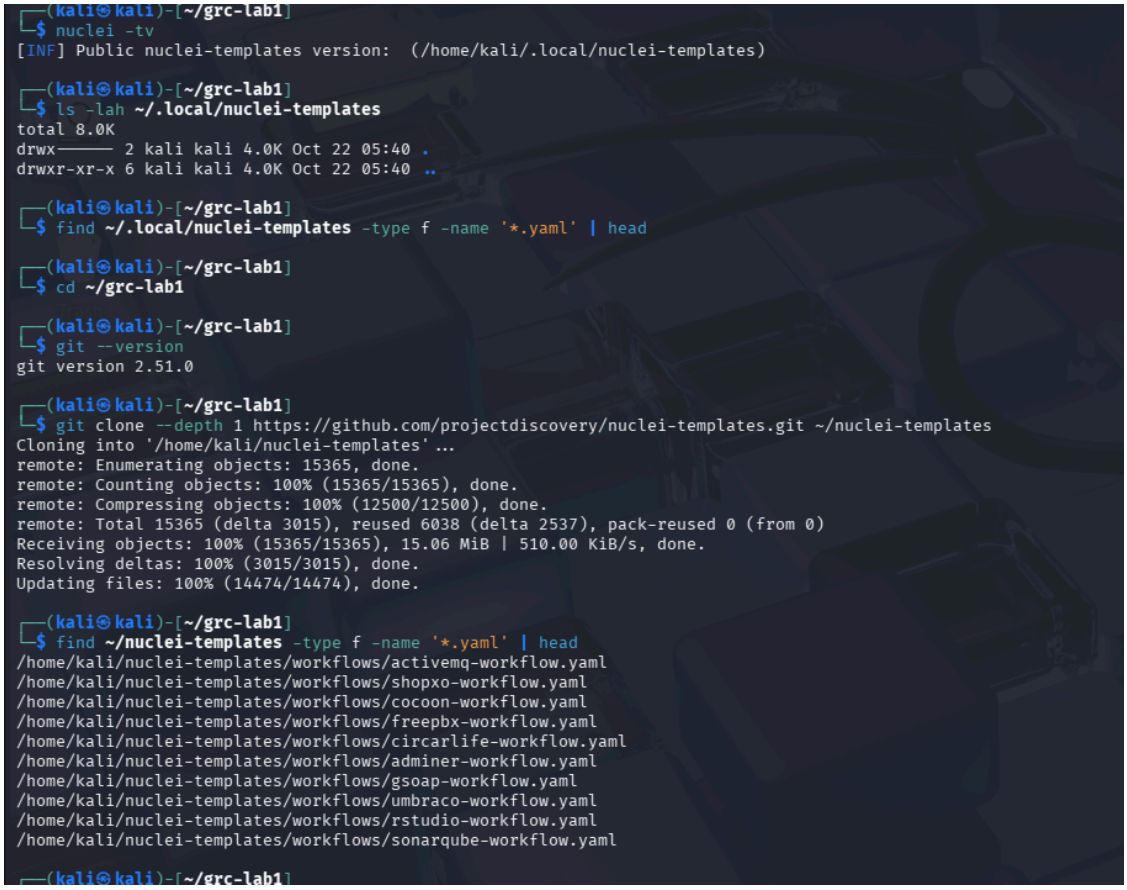



**Figure 26:** *Workaround: git clone of nuclei-templates (14,474 files)*

## Results

With templates in place Nuclei produced **59 results**: 4 critical, 18 high, 2 medium, 2 low and 33 informational. Nuclei output often includes CVE references and severity labels, which is crucial evidence for the risk assessment. The complete output is in Appendix A.

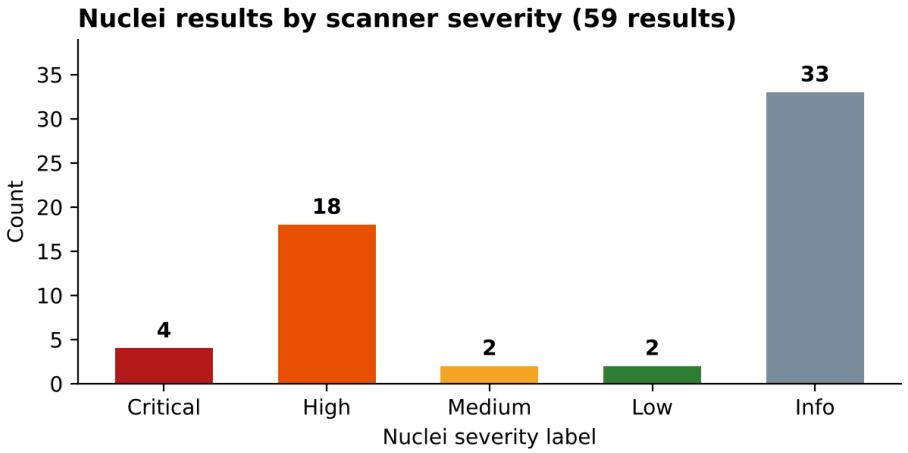



**Figure 27:** *Nuclei results by scanner severity label*

**Table 10:** *Nuclei critical and high results (grouped)*

| Template | Severity | Target | Meaning | Finding |
|---|---|---|---|---|
| CVE-2011-2523 | Critical | :6200 | vsftpd 2.3.4 backdoor shell port | R01 |
| pgsql-empty-password | Critical | :5432 | PostgreSQL accepts an empty password | R03 |
| CVE-2020-1938 | Critical | :8009 | Tomcat AJP file read/inclusion (Ghostcat) | R04 |
| CVE-2026-4480:version | Critical | :445 | Samba 3.0.20 version matches a printing command injection | R11 |
| CVE-2004-2687 | High | :3632 | distcc remote command execution | R05 |
| vnc-default-login (x2) | High | :5900 | Passwords 'password' and 'password123' | R06 |
| postgres-default-logins; pgsql-default-db (x4) | High | :5432 | postgres/postgres and empty passwords on databases postgres and template1 | R03 |
| ftp-weak-credentials (x8) | High | :21 | User 'ftp' with 8 passwords (likely the anonymous account) | R10 |
| CVE-2012-1823 | High | :80 | PHP-CGI argument injection | R13 |
| CVE-2021-30047:version | High | :21 | vsftpd 3.0.3 denial of service; probable false positive for 2.3.4 | R30 |

Note: results from version-based templates (CVE-2026-4480, CVE-2015-1419, CVE-2021-30047) are not proof of exploitability and need validation of the installed build.

# 5. Phase 3: Analysis and Reporting

## 5.1 Step 6: Triage and risk assessment

The table below uses the lab's columns (Finding, Affected Service, CVE/Reference, Inherent Risk, Compliance Violation, Business Impact). Inherent risk is the lab's H/M/L, with the more granular rating alongside. Criteria from the lab: **High** = easy to exploit and leads to full system compromise; **Medium** = requires some skill and leads to data leakage; **Low** = information disclosure, low impact. Scoring: Likelihood (1-5) x Impact (1-5); Critical 20+, High 12-19, Medium 8-11, Low below 8. Critical and High both map to lab High.

**Table 11:** *Risk assessment table (lab format) - all findings*

| ID | Finding | Affected service | CVE / reference | Inherent risk (L/M/H) | Rating | Compliance violation (indicative) | Business impact |
|---|---|---|---|---|---|---|---|
| **R01** | vsftpd 2.3.4 backdoor detected | TCP/21 (backdoor shell TCP/6200) | CVE-2011-2523 | **H** | **Critical** | CIS 7.1, 7.4, 7.7; CSF ID.RA-01; PR.PS-02; ISO A.8.8 | Unauthenticated remote root-level command execution leading to full host compromise, data theft, and use of the host as a pivot point. |
| **R02** | Bind shell identified as 'Metasploitable root shell' | TCP/1524 | Nmap service identification (no CVE) | **H** | **Critical** | CIS 4.1, 4.8; CSF PR.PS-01; ISO A.8.9 | Direct, unauthenticated privileged access to the operating system; complete loss of confidentiality, integrity and availability. |
| **R03** | PostgreSQL accessible with empty and default credentials | TCP/5432 | Nuclei: pgsql-empty-password; postgres-default-logins; pgsql-default-db | **H** | **Critical** | CIS 4.7, 5.2, 6.1; CSF PR.AA-01; PR.AA-03; ISO A.5.17; A.8.5 | Full read/write access to all databases; possible server-side file access and command execution through superuser features; data breach or tampering. |
| **R04** | Apache JServ (AJP) 'Ghostcat' vulnerability | TCP/8009 | CVE-2020-1938 | **H** | **Critical** | CIS 7.1, 7.4, 7.7; CSF ID.RA-01; PR.PS-02; ISO A.8.8 | Disclosure of application source and configuration (including credentials) and possible remote code execution. |
| **R05** | distccd remote command execution | TCP/3632 | CVE-2004-2687 | **H** | **Critical** | CIS 4.1, 4.8; CSF PR.PS-01; ISO A.8.9 | Unauthenticated remote command execution as the daemon user and a stepping stone to privilege escalation. |
| **R06** | VNC remote desktop with weak password and weak protocol | TCP/5900 | Nuclei: vnc-default-login; vnc-service-detect | **H** | **Critical** | CIS 4.7, 5.2, 6.1; CSF PR.AA-01; PR.AA-03; ISO A.5.17; A.8.5 | Interactive desktop control of the host, enabling full compromise, credential capture and tampering. |
| **R07** | UnrealIRCd 3.2.8.1 (release known to have been trojaned) | TCP/6667, 6697 | CVE-2010-2075 (applicability to validate) | **H** | **High** | CIS 7.1, 7.4, 7.7; CSF ID.RA-01; PR.PS-02; ISO A.8.8 | If trojaned: unauthenticated remote command execution. Otherwise: an unnecessary, outdated chat service. |
| **R08** | Telnet service exposed (cleartext remote login) | TCP/23 | No CVE (insecure protocol) | **H** | **High** | CIS 3.10, 12.6; CSF PR.DS-02; ISO A.8.24; A.5.14 | Credential and session interception on any shared network path, leading to unauthorised access. |
| **R09** | Legacy r-services exposed (rexec, rlogin, rsh) | TCP/512, 513, 514 | No CVE (insecure protocols) | **H** | **High** | CIS 3.10, 12.6; CSF PR.DS-02; ISO A.8.24; A.5.14 | Unauthorised command execution or login through trusted-host abuse and credential interception. |
| **R10** | Anonymous FTP login and weak FTP credentials | TCP/21 | Nmap ftp-anon; Nuclei ftp-anonymous-login; ftp-weak-credentials | **H** | **High** | CIS 4.7, 5.2, 6.1; CSF PR.AA-01; PR.AA-03; ISO A.5.17; A.8.5 | Unauthorised file access or upload, service abuse, and interception of any credentials or data sent over FTP. |
| **R11** | Samba 3.0.20 flagged for CVE-2026-4480 (version-based) | TCP/445 | CVE-2026-4480 | **H** | **High** | CIS 7.1, 7.4, 7.7; CSF ID.RA-01; PR.PS-02; ISO A.8.8 | Potential remote code execution on the file server. |

| ID | Finding | Affected service | CVE / reference | Inherent risk (L/M/H) | Rating | Compliance violation (indicative) | Business impact |
|---|---|---|---|---|---|---|---|
| **R12** | SMB weaknesses: SMBv1, guest access and signing disabled | TCP/139, 445 (UDP/137) | Nmap smb-security-mode; Nuclei smb-v1-supported | **H** | **High** | CIS 3.3, 6.1, 6.8; CSF PR.AA-05; ISO A.5.15; A.8.3 | Unauthorised share access, information disclosure and man-in-the-middle manipulation of SMB traffic. |
| **R13** | PHP-CGI argument injection | TCP/80 | CVE-2012-1823 | **H** | **High** | CIS 7.1, 7.4, 7.7; CSF ID.RA-01; PR.PS-02; ISO A.8.8 | Source-code disclosure and potential remote code execution through the web server. |
| **R14** | End-of-life web stack: Apache 2.2.8 and PHP 5.2.4 | TCP/80 | Nikto outdated-version notice; Nuclei apache-httpd-eol and php-eol | **H** | **High** | CIS 2.2, 7.4, 7.7; CSF PR.PS-02; ID.RA-01; ISO A.8.8; A.8.19 | Web compromise, information disclosure or denial of service; non-compliance with patching expectations. |
| **R15** | Legacy database services exposed to the network | TCP/3306, 5432 | Nmap version banners; Nuclei pgsql-detect | **H** | **High** | CIS 2.2, 7.4, 7.7; CSF PR.PS-02; ID.RA-01; ISO A.8.8; A.8.19 | Unauthorised data access, tampering or disruption if authentication or patching is weak (see R03). |
| **R16** | Ruby DRb (distributed Ruby) service exposed | TCP/8787 | Nmap service identification | **H** | **High** | CIS 4.1, 4.8; CSF PR.PS-01; ISO A.8.9 | Potential remote code execution on the host. |
| **R17** | End-of-life Apache Tomcat 5.5 application server | TCP/8180 | Nmap http-title 'Apache Tomcat/5.5' | **H** | **High** | CIS 2.2, 7.4, 7.7; CSF PR.PS-02; ID.RA-01; ISO A.8.8; A.8.19 | Application compromise, credential exposure and possible code deployment through management interfaces. |
| **R18** | SSLv2 and weak ciphers supported by SMTP service | TCP/25 | Nmap sslv2 script; obsolete protocol (no CVE) | **H** | **High** | CIS 3.10, 12.6; CSF PR.DS-02; ISO A.8.24; A.5.14 | Weakened confidentiality and integrity of mail transport and possible downgrade attacks. |
| **R19** | Unsupported legacy operating system | Host | Nmap OS detection | **H** | **High** | CIS 2.2, 7.4, 7.7; CSF PR.PS-02; ID.RA-01; ISO A.8.8; A.8.19 | Persistent exposure to known kernel and library vulnerabilities, including local privilege escalation. |
| **R20** | Excessive attack surface and no network filtering | 30 open TCP ports | Nmap full TCP scan | **H** | **High** | CIS 4.4, 12.2, 13.4; CSF PR.IR-01; ISO A.8.20; A.8.22 | Large attack surface that multiplies the likelihood that at least one weakness is exploited. |
| **R21** | NFS and RPC portmapper services exposed | TCP/111, 2049, 54313, 54570, 54727 (UDP/111) | Nmap rpcinfo; Nuclei nfs-v3-exposed, rpc-udp-detect | **M** | **Medium** | CIS 3.3, 6.1, 6.8; CSF PR.AA-05; ISO A.5.15; A.8.3 | Possible unauthorised file read/write if exports are open. |
| **R22** | phpMyAdmin administration interface exposed | TCP/80 | Nikto; Nuclei phpmyadmin-panel | **M** | **Medium** | CIS 3.3, 6.1, 6.8; CSF PR.AA-05; ISO A.5.15; A.8.3 | Database takeover if weak credentials or vulnerabilities exist. |
| **R23** | phpinfo() test script exposed | TCP/80 | CWE-552; Nuclei phpinfo-files | **M** | **Medium** | CIS 16.7, 4.1; CSF PR.PS-01; ISO A.8.9 | Reconnaissance data that makes targeted attacks easier. |
| **R24** | Directory indexing and browsable documentation paths | TCP/80 | CVE-1999-0678 (/doc/); Nikto | **M** | **Medium** | CIS 16.7; CSF PR.PS-01; ISO A.8.9; A.8.26 | Information disclosure and discovery of further attack targets. |
| **R25** | Possible credential file '#wp-config.php#' reported | TCP/80 | Nikto finding | **M** | **Medium** | CIS 16.7, 4.1; CSF PR.PS-01; ISO A.8.9 | If confirmed: disclosure of database credentials and takeover of the application's data. |
| **R26** | Legacy OpenSSH 4.7p1 with 1024-bit DSA host key | TCP/22 | Nmap ssh-hostkey; Nuclei openssh-detect | **M** | **Medium** | CIS 2.2, 7.4, 7.7; CSF PR.PS-02; ID.RA-01; ISO A.8.8; A.8.19 | Weak cryptographic assurance and exposure to known OpenSSH flaws. |
| **R27** | Legacy ISC BIND 9.4.2 DNS service | TCP/53 | Nmap dns-nsid | **M** | **Medium** | CIS 2.2, 7.4, 7.7; CSF PR.PS-02; ID.RA-01; ISO A.8.8; A.8.19 | Exposure to DNS software flaws and possible abuse as a resolver. |
| **R28** | Legacy ProFTPD 1.3.1 on alternate FTP port | TCP/2121 | Nmap -sV | **M** | **Medium** | CIS 2.2, 7.4, 7.7; CSF PR.PS-02; ID.RA-01; ISO A.8.8; A.8.19 | Cleartext file transfer and exposure to ProFTPD vulnerabilities. |
| **R29** | Java RMI registry services exposed | TCP/1099, 59365 | Nmap -sV | **M** | **Medium** | CIS 4.1, 4.8; CSF PR.PS-01; ISO A.8.9 | Potential remote code execution or information disclosure. |
| **R30** | Additional vsftpd CVEs flagged by version match | TCP/21 | CVE-2015-1419; CVE-2021-30047 | **M** | **Medium** | CIS 7.1, 7.4, 7.7; CSF ID.RA-01; PR.PS-02; ISO A.8.8 | Access-restriction bypass or denial of service of the FTP service. |

| ID | Finding | Affected service | CVE / reference | Inherent risk (L/M/H) | Rating | Compliance violation (indicative) | Business impact |
|---|---|---|---|---|---|---|---|
| **R31** | Expired TLS certificates on SMTP and PostgreSQL | TCP/25, 5432 | Nmap ssl-cert; ssl-date | **L** | **Low** | CIS 3.10, 12.6; CSF PR.DS-02; ISO A.8.24; A.5.14 | Trust failure, certificate warnings that train users to ignore errors, and weakened transport security. |
| **R32** | SMTP user enumeration commands enabled (VRFY, ETRN) | TCP/25 | Nmap smtp-commands; Nuclei smtp-commands-enum | **L** | **Low** | CIS 16.7, 4.1; CSF PR.PS-01; ISO A.8.9 | Account discovery that supports password-guessing and phishing. |
| **R33** | HTTP TRACE method enabled | TCP/80 | Cross-Site Tracing (OWASP); Nuclei http-trace | **L** | **Low** | CIS 16.7; CSF PR.PS-01; ISO A.8.9; A.8.26 | Low on its own; adds to client-side attack options. |
| **R34** | Missing HTTP security response headers | TCP/80 | OWASP Secure Headers; Nuclei http-missing-security-headers | **L** | **Low** | CIS 16.7; CSF PR.PS-01; ISO A.8.9; A.8.26 | Increased exposure of users to client-side attacks. |
| **R35** | Information leakage through headers, ETag and error behaviour | TCP/80 | CVE-2003-1418; OSVDB-12184; Nuclei apache-mod-negotiation-listing | **L** | **Low** | CIS 16.7, 4.1; CSF PR.PS-01; ISO A.8.9 | Reconnaissance value only; supports other attacks. |
| **R36** | Large clock skew relative to scanner | Host | Nmap clock-skew | **L** | **Low** | CIS 8.4; CSF PR.PS-04; ISO A.8.17 | Unreliable log timelines for investigations. |
| **R37** | X11 service listening | TCP/6000 | Nmap -sV | **L** | **Low** | CIS 4.1, 4.8; CSF PR.PS-01; ISO A.8.9 | Potential screen/keystroke exposure if access control is relaxed. |
| **R38** | NetBIOS and RPC information disclosure | UDP/137, UDP/111 | Nuclei netbios-udp-detect, rpc-udp-detect; Nmap nbstat, smb-os-discovery | **L** | **Low** | CIS 16.7, 4.1; CSF PR.PS-01; ISO A.8.9 | Reconnaissance support. |

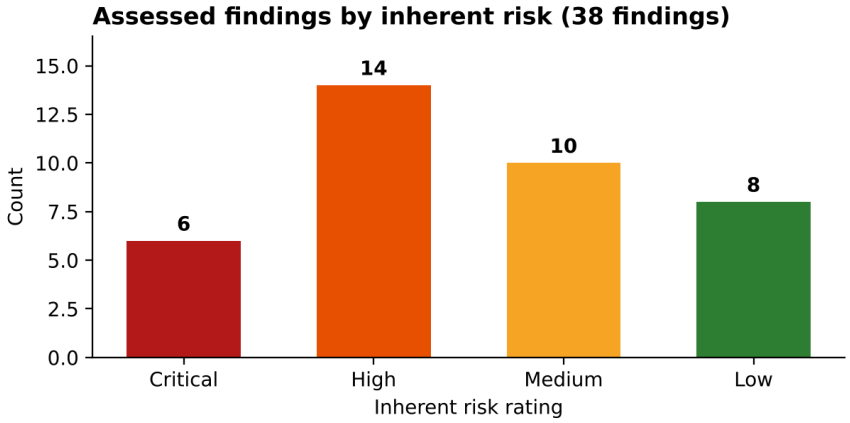



**Figure 28:** *Assessed findings by inherent risk rating*

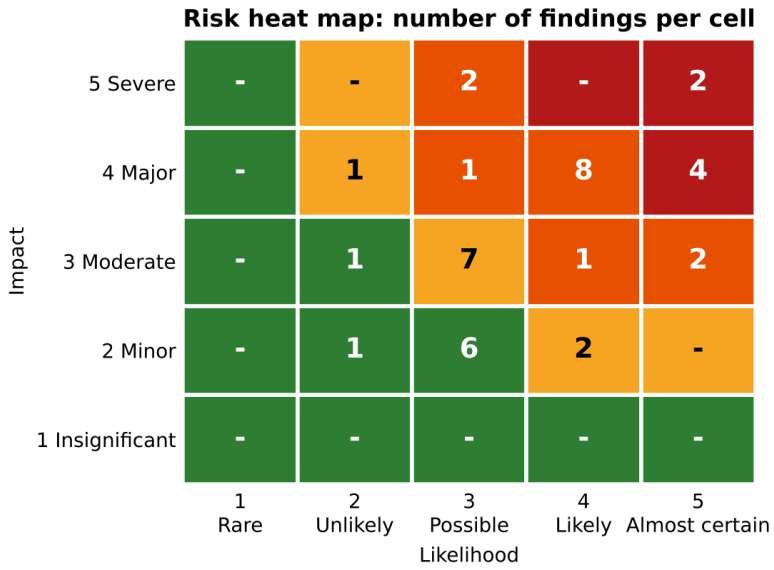



**Figure 29:** *Heat map of findings by likelihood and impact*

The three rows quoted as examples in the lab brief are all present: weak default credentials (R03, R06, R10), the vsFTPd 2.3.4 backdoor (R01, CVE-2011-2523) and unencrypted Telnet (R08). Detailed cards for each finding, with evidence, owners and target dates, are in the vulnerability report.

## 5.2 Step 7: Executive summary

| | |
|---|---|
| **To** | IT Management |
| **From** | GRC Audit Team |
| **Date** | 23 October 2026 |
| **Subject** | High-Risk Findings on Development Server 'metasploitable' |

### 1. Executive Summary

A vulnerability assessment of the internal server 'metasploitable' (192.168.164.129) revealed multiple critical security vulnerabilities that pose an immediate and high risk to the organisation's information assets. There are 38 findings: 6 critical, 14 high, 10 medium and 8 low. The system is not aligned with several key organisational policies based on the CIS Controls (secure configuration, vulnerability management, access control and protection of data in transit).

### 2. Key Findings and Risks

- **Critical risk - remote system compromise:** the FTP service contains a known backdoor (CVE-2011-2523) that allowed a shell port to be detected, and a root shell service is open on port 1524. Attackers can gain full control without authentication. This violates our patch management policy (CIS Control 7.1).
- **Critical risk - default credentials:** the PostgreSQL database accepts an empty password and VNC accepts weak passwords (CIS 4.7, 5.2).
- **Critical risk - remote execution services:** distccd and the Tomcat AJP connector are exposed.

- **High risk - data interception:** Telnet, rlogin/rsh/rexec and FTP transmit credentials in plaintext and the mail server supports SSLv2, violating data protection standards (NIST CSF PR.DS-02) and risking credential theft.
- **High risk - obsolete software and weak authentication:** unsupported operating system, web, database and file-sharing software; default and weak passwords (CIS 5.2); anonymous FTP.

## 3. Recommended Actions

1. **Immediate isolation:** remove the server from the network until remediated.
2. **Remediate:** apply security patches, especially to vsFTPd; remove the bind shell, distccd and AJP; reset database and VNC credentials.
3. **Harden:** disable unnecessary services (Telnet, rlogin/rsh/rexec, IRC, anonymous FTP); enforce strong passwords and a default-deny firewall.
4. **Process review:** reinforce procedures for deploying systems according to security baselines.
5. **Retest** after remediation and record the Nuclei template version.

# 6. Remediation Plan

**Table 12:** *Remediation phases, findings and target dates*

| Phase | Findings | Key actions | Target |
|---|---|---|---|
| **Contain** | All | Isolate on host-only network; snapshot; record owner | Immediately |
| **P1 Critical** | R01, R02, R03, R04, R05, R06 | Disable vsftpd, bind shell, distccd, AJP; reset PostgreSQL and VNC credentials; default-deny firewall | 30 Oct 2026 (7 days) |
| **P2 High** | R07, R08, R09, R10, R11, R12, R13, R14, R15, R16, R17, R18, R19, R20 | Disable Telnet, r-services, anonymous FTP, IRC; patch or retire legacy software; disable SMBv1; remove SSLv2 | 22 Nov 2026 (30 days) |
| **P3 Medium** | R21, R22, R23, R24, R25, R26, R27, R28, R29, R30 | Restrict NFS, phpMyAdmin, RMI; remove test content; upgrade SSH, BIND, ProFTPD | 21 Jan 2027 (90 days) |
| **P4 Low** | R31, R32, R33, R34, R35, R36, R37, R38 | Security headers, banners, TRACE/VRFY, certificates, NTP | 21 Apr 2027 (180 days) |

# 7. Lessons Learned and Limitations

## 7.1 Lessons learned

- **Banner is not proof.** Version strings suggest CVEs but do not prove exploitability; each finding carries a confidence label.
- **Tool failure is itself evidence.** The Nuclei template timeout was logged, diagnosed and resolved rather than reported as a clean scan.
- **Scanner severity needs judgement.** I adjusted the severity of several results (distccd up, Samba down, the eight FTP password hits counted once, CVE-2021-30047 flagged as a probable false positive).
- **GRC value is in interpretation.** Mapping technical results to control objectives and business impact is what makes the output useful to management.

## 7.2 Limitations

**Table 13:** *Limitations*

| ID | Limitation | Next step | Status |
|---|---|---|---|
| **L01** | **Nuclei template download failed** | Resolved: templates were obtained with 'git clone --depth 1 https://github.com/projectdiscovery/nuclei-templates.git ~/nuclei-templates' (14,474 files) and the scan completed with 59 results. Record the template version used and retain the template update log. | Closed |
| **L02** | **Scanner results are partly version-based** | Validate installed package builds and configuration before treating as confirmed exploitable. | Open |
| **L03** | **No credentialed or authenticated testing** | Perform a credentialed scan or configuration review (for example with Lynis or OpenSCAP) to confirm findings. | Open |
| **L04** | **UDP ports not scanned** | Run a targeted UDP scan (for example nmap -sU --top-ports 100). | Open |
| **L05** | **Single point-in-time, same-segment assessment** | Repeat after remediation and from a representative network location. | Open |
| **L06** | **No exploitation performed** | Obtain explicit approval before any manual validation of backdoors or shells. | Noted |
| **L07** | **Possible scanner false positives** | Review each item manually and record the outcome. | Open |

# 8. Conclusion

I progressed from technical scanning to risk analysis, which the lab identifies as a critical GRC competency. The host exposes 30 services with no filtering, several with known backdoors or default credentials, and most software is end of life. The results are mapped to CIS, NIST CSF, ISO 27001, PCI DSS and OWASP, rated by likelihood and impact, and turned into a time-bound remediation plan. The value lies not in running the tools but in interpreting results to drive business-focused risk decisions.

# 9. Evidence Inventory

**Table 14:** *Evidence files*

| File | Description |
|---|---|
| evidence/initial_scan.nmap, .xml, .gnmap | Nmap raw output (saved 05:00) |
| evidence/initial_scan_report.html | HTML report generated with xsltproc (05:18) |
| Nmap Scan Report ... .html / .pdf | Browser copies (05:22-05:23) |
| evidence/nikto_scan.txt | Nikto output (05:31) |
| evidence/nuclei_template_update.txt | Template update failure log (468 bytes) |
| evidence/nuclei_scan.txt | Nuclei results (59 lines); the first 0-byte file must be replaced by the re-run output |

# Appendix A. Nuclei Results (all)

**Table 15:** *Complete Nuclei output with severity and mapped finding*

| # | Template ID | Proto | Severity | Target | Detail | Finding |
|---|---|---|---|---|---|---|
| 1 | **CVE-2012-1823** | http | **High** | 192.168.164.129/index.php?-d+allow_url_include%3don+-d+au... | | R13 |
| 2 | **phpmyadmin-panel** | http | **Info** | 192.168.164.129/phpMyAdmin/ | [paths="/phpMyAdmin/"] | R22 |
| 3 | **phpinfo-files** | http | **Low** | 192.168.164.129/phpinfo.php | [paths="/phpinfo.php"] | R23 |
| 4 | **http-trace:trace-request** | http | **Info** | 192.168.164.129 | | R33 |
| 5 | **apache-mod-negotiation-listing:exposed_files** | http | **Low** | 192.168.164.129/index | ["index.php"] [path="/index"] | R35 |
| 6 | **php-detect** | http | **Info** | 192.168.164.129 | ["5.2.4"] | R14 |
| 7 | **waf-detect:apachegeneric** | http | **Info** | 192.168.164.129 | | R35 |
| 8 | **CVE-2026-4480:version** | javascript | **Critical** | 192.168.164.129:445 | ["3.0.20"] | R11 |
| 9 | **postgres-default-logins** | javascript | **High** | 192.168.164.129:5432 | passwords='postgres', usernames='postgres' | R03 |
| 10 | **vnc-default-login** | javascript | **High** | 192.168.164.129:5900 | passwords='password' | R06 |
| 11 | **vnc-default-login** | javascript | **High** | 192.168.164.129:5900 | passwords='password123' | R06 |
| 12 | **samba-detect** | javascript | **Info** | 192.168.164.129:445 | ["Samba 3.0.20-Debian"] | R11 |
| 13 | **pgsql-default-db** | javascript | **High** | 192.168.164.129:5432 | database='postgres', password='postgres', usernames='postgres' | R03 |
| 14 | **pgsql-default-db** | javascript | **High** | 192.168.164.129:5432 | database='postgres', password='', usernames='postgres' | R03 |
| 15 | **pgsql-default-db** | javascript | **High** | 192.168.164.129:5432 | database='template1', password='postgres', usernames='postgres' | R03 |
| 16 | **pgsql-default-db** | javascript | **High** | 192.168.164.129:5432 | database='template1', password='', usernames='postgres' | R03 |
| 17 | **ntlm-info** | javascript | **Info** | 192.168.164.129:445 | ["NTLM: Samba 3.0.20-Debian"] | R12 |
| 18 | **smb-v1-supported** | javascript | **Info** | 192.168.164.129:445 | | R12 |
| 19 | **smb-version-detect:smb-version** | javascript | **Info** | 192.168.164.129:445 | ["SMB 1.0"] | R12 |
| 20 | **pgsql-empty-password** | javascript | **Critical** | 192.168.164.129:5432 | | R03 |
| 21 | **netbios-udp-detect** | javascript | **Info** | 192.168.164.129:137 | ["NetBIOS Name Service Detected"] | R38 |
| 22 | **rpc-udp-detect** | javascript | **Info** | 192.168.164.129:111 | ["RPC Portmapper UDP Detected"] | R38 |
| 23 | **CVE-2004-2687** | tcp | **High** | 192.168.164.129:3632 | | R05 |
| 24 | **CVE-2015-1419:version** | tcp | **Medium** | 192.168.164.129:21 | ["2.3.4"] | R30 |
| 25 | **CVE-2021-30047:version** | tcp | **High** | 192.168.164.129:21 | ["2.3.4"] | R30 |
| 26 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='password', username='ftp' | R10 |
| 27 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='default', username='ftp' | R10 |
| 28 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='nas', username='ftp' | R10 |
| 29 | **ftp-detect** | tcp | **Info** | 192.168.164.129:21 | | R10 |
| 30 | **vsftpd-detect:version** | tcp | **Info** | 192.168.164.129:21 | ["2.3.4"] | R01 |
| 31 | **nfs-v3-exposed** | tcp | **Info** | 192.168.164.129:2049 | | R21 |
| 32 | **pgsql-detect** | tcp | **Info** | 192.168.164.129:5432 | | R15 |
| 33 | **openssh-detect** | tcp | **Info** | 192.168.164.129:22 | ["SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1"] | R26 |

| # | Template ID | Proto | Severity | Target | Detail | Finding |
|---|---|---|---|---|---|---|
| 34 | **vnc-service-detect** | tcp | **Info** | 192.168.164.129:5900 | ["RFB 003.003"] | R06 |
| 35 | **CVE-2020-1938** | tcp | **Critical** | 192.168.164.129:8009 | | R04 |
| 36 | **smtp-detect** | tcp | **Info** | 192.168.164.129:25 | | R32 |
| 37 | **esmtp-detect** | tcp | **Info** | 192.168.164.129:25 | | R32 |
| 38 | **smtp-commands-enum:ehlo** | tcp | **Info** | 192.168.164.129:25 | ["DSN","PIPELINING","SIZE 10240000","VRFY","ETRN","STARTTLS","ENHANCEDSTATUSCODES","8BITMIME"] | R32 |
| 39 | **CVE-2011-2523** | tcp | **Critical** | 192.168.164.129:6200 | | R01 |
| 40 | **ftp-anonymous-login** | tcp | **Medium** | 192.168.164.129:21 | | R10 |
| 41 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='123456', username='ftp' | R10 |
| 42 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='guest', username='ftp' | R10 |
| 43 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='stingray', username='ftp' | R10 |
| 44 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='pass1', username='ftp' | R10 |
| 45 | **ftp-weak-credentials** | tcp | **High** | 192.168.164.129:21 | password='toor', username='ftp' | R10 |
| 46 | **apache-detect** | http | **Info** | 192.168.164.129 | ["Apache/2.2.8 (Ubuntu) DAV/2"] | R14 |
| 47 | **apache-httpd-eol:version** | http | **Info** | 192.168.164.129 | ["2.2.8"] | R14 |
| 48 | **php-eol:version** | http | **Info** | 192.168.164.129 | ["5.2.4"] | R14 |
| 49 | **tech-detect:php** | http | **Info** | 192.168.164.129 | | R35 |
| 50 | **http-missing-security-headers:content-security-policy** | http | **Info** | 192.168.164.129 | Missing header: content-security-policy | R34 |
| 51 | **http-missing-security-headers:x-content-type-options** | http | **Info** | 192.168.164.129 | Missing header: x-content-type-options | R34 |
| 52 | **http-missing-security-headers:x-permitted-cross-domain-policies** | http | **Info** | 192.168.164.129 | Missing header: x-permitted-cross-domain-policies | R34 |
| 53 | **http-missing-security-headers:cross-origin-opener-policy** | http | **Info** | 192.168.164.129 | Missing header: cross-origin-opener-policy | R34 |
| 54 | **http-missing-security-headers:permissions-policy** | http | **Info** | 192.168.164.129 | Missing header: permissions-policy | R34 |
| 55 | **http-missing-security-headers:x-frame-options** | http | **Info** | 192.168.164.129 | Missing header: x-frame-options | R34 |
| 56 | **http-missing-security-headers:referrer-policy** | http | **Info** | 192.168.164.129 | Missing header: referrer-policy | R34 |
| 57 | **http-missing-security-headers:cross-origin-embedder-policy** | http | **Info** | 192.168.164.129 | Missing header: cross-origin-embedder-policy | R34 |
| 58 | **http-missing-security-headers:cross-origin-resource-policy** | http | **Info** | 192.168.164.129 | Missing header: cross-origin-resource-policy | R34 |
| 59 | **http-missing-security-headers:strict-transport-security** | http | **Info** | 192.168.164.129 | Missing header: strict-transport-security | R34 |

# Appendix B. Nikto Results (27 items)

**Table 16:** *Complete Nikto output with category and mapped finding*

| # | Finding reported by Nikto | Path | Category | Finding |
|---|---|---|---|---|
| 1 | X-Powered-By header retrieved: PHP/5.2.4-2ubuntu5.10 | / | Information disclosure | R35 |
| 2 | Anti-clickjacking X-Frame-Options header not present | / | Missing header | R34 |
| 3 | X-Content-Type-Options header not set (MIME sniffing) | / | Missing header | R34 |
| 4 | Apache/2.2.8 outdated (current is at least 2.4.54; 2.2.34 is EOL for the 2.x branch) | / | Outdated software | R14 |
| 5 | Uncommon header 'tcn' found, with contents: list | /index | Information disclosure | R35 |
| 6 | mod_negotiation enabled with MultiViews; alternative 'index.php' found (file-name brute forcing) | /index | Misconfiguration | R35 |
| 7 | Server returns a valid response with junk HTTP methods (KOVKERUA); possible false positive | / | Behaviour / possible false positive | R35 |
| 8 | HTTP TRACE method active (suggests vulnerability to XST) | / | Insecure method | R33 |
| 9 | Output from phpinfo() found | /phpinfo.php | Information disclosure | R23 |
| 10 | Directory indexing found | /doc/ | Directory listing | R24 |
| 11 | /doc/ directory browsable (may be /usr/doc), CVE-1999-0678 | /doc/ | Directory listing | R24 |
| 12 | PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000 | /?=PHPB8B5F2A0-... | Information disclosure | R35 |
| 13 | PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPE9568F36-D428-11d2-A769-00AA001ACF42 | /?=PHPE9568F36-... | Information disclosure | R35 |
| 14 | PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPE9568F34-D428-11d2-A769-00AA001ACF42 | /?=PHPE9568F34-... | Information disclosure | R35 |
| 15 | PHP reveals potentially sensitive information via query string (OSVDB-12184) - ID PHPE9568F35-D428-11d2-A769-00AA001ACF42 | /?=PHPE9568F35-... | Information disclosure | R35 |
| 16 | phpMyAdmin is for managing MySQL databases and should be protected or limited to authorized hosts | /phpMyAdmin/changelog.php | Exposed admin interface | R22 |
| 17 | Server may leak inodes via ETags; ChangeLog inode 92462, size 40540, mtime 9 Dec 2008 (CVE-2003-1418) | /phpMyAdmin/ChangeLog | Information disclosure | R35 |
| 18 | phpMyAdmin should be protected or limited to authorized hosts | /phpMyAdmin/ChangeLog | Exposed admin interface | R22 |
| 19 | Directory indexing found | /test/ | Directory listing | R24 |
| 20 | 'This might be interesting' - test content present | /test/ | Test content | R24 |
| 21 | PHP installed and a test script that runs phpinfo() found (CWE-552) | /phpinfo.php | Information disclosure | R23 |
| 22 | Directory indexing found | /icons/ | Directory listing | R24 |
| 23 | Apache default file found | /icons/README | Default content | R24 |
| 24 | phpMyAdmin directory found | /phpMyAdmin/ | Exposed admin interface | R22 |
| 25 | phpMyAdmin documentation exposed | /phpMyAdmin/Documentation.html | Exposed admin interface | R22 |
| 26 | phpMyAdmin README exposed | /phpMyAdmin/README | Exposed admin interface | R22 |
| 27 | '#wp-config.php#' file reported (may contain credentials) - unverified | /#wp-config.php# | Possible credential exposure | R25 |

# Appendix C. Nmap Grepable Output

```
# Nmap 7.95 scan initiated Thu Oct 22 04:57:27 2026 as:
# /usr/lib/nmap/nmap --privileged -sV -sC -O -p- -oA evidence/initial_scan 192.168.164.129
Host: 192.168.164.129 ()  Status: Up
Host: 192.168.164.129 ()  Ports:
 21/open/tcp//ftp//vsftpd 2.3.4/, 22/open/tcp//ssh//OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)/,
 23/open/tcp//telnet//Linux telnetd/, 25/open/tcp//smtp//Postfix smtpd/,
 53/open/tcp//domain//ISC BIND 9.4.2/, 80/open/tcp//http//Apache httpd 2.2.8 ((Ubuntu) DAV/2)/,
 111/open/tcp//rpcbind//2 (RPC #100000)/, 139/open/tcp//netbios-ssn//Samba smbd 3.X - 4.X (workgroup:
WORKGROUP)/,
 445/open/tcp//netbios-ssn//Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)/,
 512/open/tcp//exec//netkit-rsh rexecd/, 513/open/tcp//login?///, 514/open/tcp//shell//Netkit rshd/,
 1099/open/tcp//java-rmi//GNU Classpath grmiregistry/, 1524/open/tcp//bindshell//Metasploitable root
shell/,
 2049/open/tcp//nfs//2-4 (RPC #100003)/, 2121/open/tcp//ftp//ProFTPD 1.3.1/,
 3306/open/tcp//mysql//MySQL 5.0.51a-3ubuntu5/,
 3632/open/tcp//distccd//distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))/,
 5432/open/tcp//postgresql//PostgreSQL DB 8.3.0 - 8.3.7/, 5900/open/tcp//vnc//VNC (protocol 3.3)/,
 6000/open/tcp//X11//(access denied)/, 6667/open/tcp//irc//UnrealIRCd/,
6697/open/tcp//irc//UnrealIRCd/,
 8009/open/tcp//ajp13//Apache Jserv (Protocol v1.3)/,
 8180/open/tcp//http//Apache Tomcat/Coyote JSP engine 1.1/,
 8787/open/tcp//drb//Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)/,
 54313/open/tcp//mountd//1-3 (RPC #100005)/, 54570/open/tcp//status//1 (RPC #100024)/,
 54727/open/tcp//nlockmgr//1-4 (RPC #100021)/, 59365/open/tcp//java-rmi//GNU Classpath grmiregistry/
 Ignored State: closed (65505)  OS: Linux 2.6.9 - 2.6.33  Seq Index: 194  IP ID Seq: All zeros
# Nmap done at Thu Oct 22 05:00:32 2026 -- 1 IP address (1 host up) scanned in 184.73 seconds
```

# Appendix D. Command Reference

**Table 17:** *Commands used in the lab*

| Purpose | Command |
|---|---|
| Create evidence folder | `mkdir -p ~/grc-lab1/evidence` |
| Connectivity | `ping -c 4 192.168.164.129` |
| Full scan, three formats | `nmap -sV -sC -O -p- -oA evidence/initial_scan 192.168.164.129` |
| HTML report | `xsltproc -o evidence/initial_scan_report.html /usr/share/nmap/nmap.xsl evidence/initial_scan.xml` |
| Web scan | `nikto -h http://192.168.164.129 -output evidence/nikto_scan.txt` |
| Nuclei scan | `nuclei -u http://192.168.164.129 -o evidence/nuclei_scan.txt` |
| Template update log | `nuclei -update-templates -debug 2>&1 \| tee evidence/nuclei_template_update.txt` |
| Template workaround | `git clone --depth 1 https://github.com/projectdiscovery/nuclei-templates.git ~/nuclei-templates` |